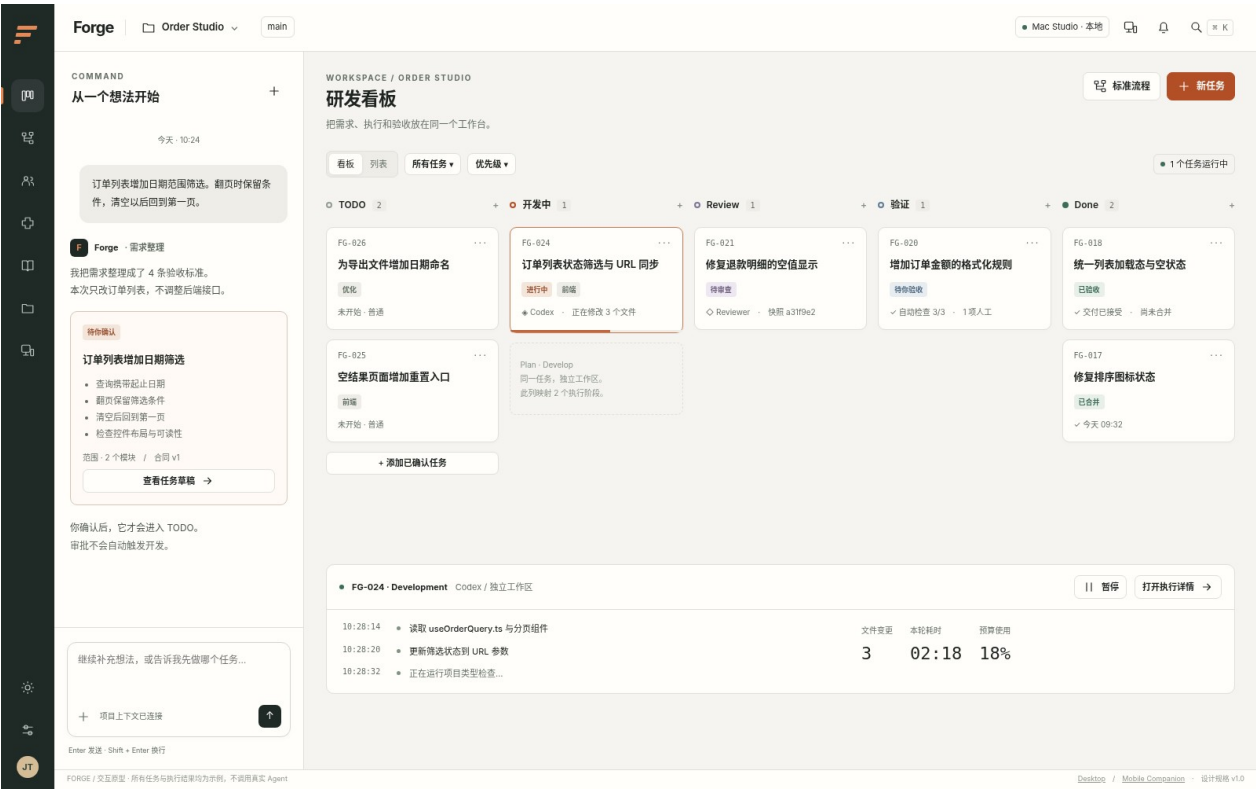


Forge

产品与工程实施蓝图

把想法整理成任务，让协作走向交付。



Desktop 高保真交互原型 · 所有任务与执行记录为示例

Windows / macOS Desktop
Plugin Architecture · Remote Host · Mobile Companion

24 个模块 / 100 个工程任务 / 120 条测试规格

18 个页面设计 · 13 份 Schema · 44 个命令 · 可点击原型

v1.0 · 2026-09-23

本文件是实施规格；原型不是已完成的应用。Forge 保持独立，不纳入 ProofRun 当前实现。

阅读导航

先理解产品边界，再按阶段实施。PDF 支持标题书签；下列目录可点击。完整契约和交互页面位于配套 Codex 实施包。

01-05 产品定位、边界、用例与状态

06-08 跨端技术与任务/执行状态

M01-M24 全部模块与实现细节

09-12 插件、调度、快照、数据与接口

13-16 远端、手机、安全与非功能要求

17-19 / D01-D15 设计系统与页面规格

P0-P9 每阶段需要完成的工程任务

T001-T120 完整功能验收规格

22 Agent 评测与受控自进化

23 命令、Schema 与数据索引

24-25 Codex 工作方式与官方来源

实施优先级

P3：首个真实开发、审查与验收闭环。

P0-P6：跨平台 Desktop v1.0。

P7-P8：远程主机与手机 PWA v1.1。

P9：高级能力，可选，不阻塞首版。

使用边界

这套文件旨在使 Codex 能够按编号增量实施，不保证一次提示直接生成所有功能。所有 SDK 能力、操作系统兼容、签名、公证与真实 Agent 效果均需在对阶段验证；测试规格不等于测试已通过。

01 · 项目约定与阅读方式

Forge 是一个自然语言驱动的 AI 研发工作台。左侧聊天负责接收想法、提问和整理草稿；用户确认后的 Task Contract 才能进入 TODO；可配置的执行阶段负责开发、Review、验证与人工验收。看板显示真实执行状态，而不是模拟团队聊天。

本文件是 Forge 的独立实施规格 v1.0，编制日期 2026-09-23。它不继承任何测试产品的路线，也不在本仓库实现或依赖 ProofRun。所有运行数据、示意画面与代码片段均为规格/原型，不代表完整应用已经实现。

资料	作用	冲突规则
本蓝图 + ADR	产品边界、状态、模块、阶段与失败处理	需求语义以本蓝图为准；安全硬约束优先
contracts/	可校验的数据结构、API、SQL 与插件接口	字段以 Schema 为准；发现文档冲突必须修正后继续
planning/	编号任务、依赖、交付文件、验收条件	一次只实施一个可验收纵向切片
design/	可点击原型、设计 Token、页面规格	交互与内容参考，不把示例状态当真实后端
tests/ + AGENTS.md	功能测试清单、契约检查与 Codex 工作规程	测试不能为了“完成任务”被删减或改成空断言

文中的“必须”是交付约束；“建议”是当前技术决定；“后续”不属于 Desktop v1.0 完成条件。库版本、模型支持与操作系统最低版本在 P0 的兼容性记录中冻结。没有实测的能力必须显示“未验证”，不能通过产品开关伪造支持。

推荐阅读顺序：先读 02-06 明确边界，再读 M03/M04/M07/M08/M10 理解核心，按 P0 开始实现；页面开发对照设计原型；提交前运行对应测试。完整产品并非一次提示生成即可保证，Codex 必须逐任务实现、运行测试、保存证据并处理实际平台差异。

02 · 产品目标、边界与成功标准

要解决的问题	Forge 的行为	不承担的责任
想法模糊，重复给多个 Agent 解释	聊天整理标准任务，保留来源与用户决策	不擅自补写事实或扩大已批准范围
开发、Review、测试间手工传话	交接明确任务版本、代码快照、问题与证据	不以角色数量证明质量更高
不同执行器切换成本高	统一能力声明、适配器和交接包	不承诺任意模型与任意执行器兼容
流程固定或配置太重	默认流程开箱可用，高级模式编辑同一份流程数据	不要求普通用户先画 DAG
离开电脑后无法处理阻塞	后续手机远程查看、审批、暂停和补充需求	手机不在本地执行编程 CLI

主要用户先限定为个人开发者和小型研发团队中的单个工作区负责人。v1.0 是 Windows/macOS 桌面产品，默认本地运行、无强制云账号；需要模型或执行器时使用用户明确配置的合法认证方式。模型服务可能接收代码上下文，“本地优先”不等于完全离线。

业务指标：每个被接受任务的人工介入次数、被遗漏的必需验收项、返工循环数、端到端耗时、失败恢复成功率。对比基线必须使用相同任务与近似预算；不预设多 Agent 优于单 Agent。

v1.0 明确不做：办公室沙盘、训练基础模型、任意第三方代码插件商店、多租户 SaaS、生产部署自动化、原生移动端 CLI、全仓库并行写入、自动代替用户批准合并。

Done = 当前任务版本对应的产物已接受。Done 不等于已合并、不等于发布上线。合并是独立、显式授权的操作。

03 · 版本范围与阶段承诺

版本/阶段	交付范围	完成边界
0.1 / P0-P1	桌面骨架、项目、聊天草稿、审批入 TODO	没有执行器也可人工创建和批准任务
0.2 / P2	一个真实执行器、一项任务、代码差异	不得用 Mock 标为真实执行
0.3 / P3	Review、检查、返工、快照、恢复	同一代码版本的完整本地交付链
0.4 / P4-P5	第二执行器、插件宿主、流程定制、上下文/项目记忆	接口真实可替换，旧 Run 配置不可漂移
1.0 / P6	完整页面、设置、无障碍、macOS/Windows 安装与签名	Desktop 正式交付；无移动端也是完整版本
1.1 / P7-P8	远程 Host、私网 HTTPS、PWA 手机控制台	主机在线时远程处理任务与审批
后续 / P9	只读并行、扩展生态、经验评测、原生手机封装	独立迭代，不阻塞 1.0

平台目标：Windows 11 x64 与 macOS Apple Silicon 为首轮发布对象；macOS Intel 作为第二验证目标。明确区分应用可安装、执行器可用、项目工具链可用三件事。某执行器不支持某平台时，该组合禁用并说明原因，不让界面成功掩盖后台失败。

远端初版的 Host 是一台保持用户会话在线的 Windows/Mac 电脑，Forge 留在托盘/菜单栏运行；睡眠、关机、真正退出会导致离线。Linux/NAS 无头宿主是后续独立部署目标，不因 TypeScript 可复用就声称已支持。

估算仅用于计划：单人全职、有 AI 辅助且具备 Vue/Node 基础，P0-P6 约 60-100 个工程日，P7-P8 另约 20-35 个工程日。按顺序验收而非按日期强行上线；签名、上游兼容和双平台实机测试会影响周期。

04 · 关键术语与不变量

术语	定义
Task Contract	审批对象：需求、范围、验收项、约束、来源与决策的不可变版本
Agent Profile	角色配置：提示模板、执行器、模型选择、上下文与权限
Executor	真正执行 Agent 的适配器，不等于模型
Model Provider	Forge 自有对话/整理器可调用的推理服务接口
Workflow Revision	节点、正常路径、返工路由与门禁的冻结版本
Run / Attempt	一次任务执行；一个节点的一次尝试
CodeSnapshot	不可变 Git commit/tree 与内容哈希，不是可变目录路径
Handoff Bundle	跨阶段输入清单，引用任务、快照、证据与问题
Approval	经过已认证人类操作产生的授权记录，不是模型语句
Board Column	workflow 状态的投影视图，不直接触发绕过门禁的数据库更新

I-01 未批准的草稿不能写产品代码。I-02 审批必须绑定任务/操作版本。I-03 同一可写工作目录同时只有一个有效租约。I-04 旧 epoch 的执行回包不能推进新 Attempt。I-05 插件不能直接写核心业务表。

I-06 Review 与 Verify 必须绑定代码快照。I-07 修改快照或验收标准会使相应旧证据失效。I-08 Unknown、未执行、环境失败不等于通过。I-09 人工豁免必须显式记录，不伪造测试 pass。I-10 接口权限由 Host 决定，不相信客户端或模型声明。

I-11 每个外部副作用都有操作日志，崩溃恢复不盲目重试合并/推送等动作。I-12 卸载插件只释放运行资源，不撤销已经发生的外部副作用。I-13 远程操作与本地操作使用同一个 Command Service。I-14 Forge 与其他独立产品无源码或数据依赖。

05 · 端到端使用与验收样例

主样例：用户在左侧说“订单列表加日期筛选，翻页保留条件，清空回第一页”。整理器阅读允许的项目上下文，产生 task-contract.example.json。对于原话未明确的“刷新后是否记住日期”，列为问题，不能擅自写成承诺。

步骤	用户看到什么	系统必须做什么
草稿	标题、验收项、范围、疑点、来源	只生成 Draft；没有代码写入工具
批准	批准并加入 TODO；可选稍后开始	CAS 校验 revision/hash；原子写审批和状态
开始	执行器/权限/预计范围摘要	冻结 run_config；分配 worktree 与 lease
开发	事件、文件差异、构建结果	处理真实工具反馈，生成可验证结果
Review	阻塞意见与证据位置	读取独立快照，不只相信开发总结
验证	必需验收项对应检查或人工待办	分别记录 passed/failed/inconclusive
验收	当前快照、未解决项、合并按钮	人类接受后 Done；合并需第二次授权

返工样例：Review 发现翻页未携带日期参数，创建 issue 与 source snapshot。新开发 Attempt 得到这些 issue；修复产生新快照，旧 Review/Verify 状态标记 stale，重新检查。连续返工达到上限进入 blocked，汇总已尝试方法并请求用户决策。

变更样例：任务执行中用户说“还要导出 Excel”。先生成变更草稿，不直接注入当前运行；用户确认后按节点安全边界暂停，revision+1，创建新 Run 或显式 migration，保留旧记录。

用户点击拖拽只是 MoveTask 命令。拖到 Done 若门禁未满足，展示缺失项并保持原状态；不偷偷更改数据库。

06 · 跨端技术决策与 ADR

选择	本版决定	原因与限制
Desktop	Electron + Vue 3 + TypeScript + Vite	复用 Web UI 与 Node 执行生态；体积较大但无需重新实现原生看板
UI 基础	Reka UI + 自有 Tokens / CSS + Vue Flow	无预设视觉，保留辨识度；画布仅负责编辑，不是流程引擎
Host	平台无关 TypeScript；Desktop 用 utilityProcess 承载	核心不 import Electron；后续可在独立 Node 进程部署
存储	SQLite + Drizzle；初期单 Host 单写入者	原生模块对 Electron/Node ABI 单独构建和验证
移动	响应式 Vue PWA，后续 Capacitor iOS/Android	复用协议/状态/组件，不复制桌面三栏；手机只做控制端
仓库	Forge 单仓 Monorepo；官方插件同仓独立包	接口稳定后再独立发布 SDK/插件；不引入其他产品
插件容器	首版显式 Registry + Disposable Scope	不直接 Fork Harness；Cordis 作为后续内部替换候选而非依赖前提

Electron 的 Main/Renderer/Utility Process 提供桌面与后台分层；Tauri 2 同样支持桌面和移动，是可行替代，但本方案已有大量 Node 执行器与进程管理需求，选 Electron 降低第一版额外 Rust/Sidecar 维护。手机通过协议复用而非强求一个壳覆盖所有场景。[S01][S04][S05]

ADR-001 选 Electron 而非 Tauri；ADR-002 Host 不依赖 UI；ADR-003 内核不可被普通插件绕过；ADR-004 正常路径为 DAG、返工单独建模；ADR-005 一工作区一写入者；ADR-006 先 PWA 再原生手机；ADR-007 不裸露执行器端口；ADR-008 不把第三方插件进程等同沙箱。

版本管理：P0 生成 versions.lock.json，记录 Electron/Node ABI、pnpm、Vue、Drizzle、SQLite 绑定、SDK 与 CLI 的确切版本及许可证。提交 lockfile；CI 禁止浮动 latest；升级必须跑兼容测试。本文不伪造未经实装的版本兼容矩阵。

07 · 进程、仓库与依赖架构

apps/desktop	Electron main/preload + 壳适配
apps/web	Vue Desktop/PWA 共享业务界面
apps/host	Node-compatible Host 入口
packages/contracts	Schema / DTO / 错误码
packages/core	Task / Approval / Run / Workflow
packages/plugin-api	公开 SDK
packages/plugin-host	Registry / 生命周期 / 依赖
packages/client	Command / Query / Event transport
packages/ui	Tokens / 基础组件
packages/workspace	Git / Snapshot / Lease
packages/storage	SQL / migrations / repositories
packages/security	Policy / CredentialRef / redaction
plugins/*	官方执行器/上下文/验证器
presets/*	角色与工作流
tests/*	unit/integration/e2e/eval
docs/*	规格、ADR、兼容记录

Desktop Renderer 只使用 ForgeClient。LocalTransport 通过 preload 的窄接口进入 Main，再走固定 MessagePort/IPC 到 Host。Host 是核心表唯一写入者；内部插件通过 SDK 请求服务。SDK/CLI 在受控子进程中执行，不运行在 Renderer。后续 RemoteTransport 使用 HTTPS 命令与 SSE 事件连接同一个 Host 服务。

Main 仅负责窗口、系统文件选择、系统凭据代理、更新、菜单与宿主生命周期。无任务调度逻辑。Host 可在没有窗口的测试中运行。UI 关闭但托盘进程保留与“退出 Forge”不同，文案必须写清楚。

工作区包使用 workspace:* 并通过 exports 暴露公共入口。ESLint/dependency-cruiser 校验禁止跨包访问 src/internal。Core 不依赖任何具体执行器；插件不依赖 Vue；apps 层完成组装。[S10]

utilityProcess、Node 子进程、Git worktree 主要提供架构/故障隔离，不自动保证恶意代码安全。首版只面向用户信任的本地仓库与随应用发布的插件。[S01][S11]

08 · Task、Run、Attempt 状态与审批失效

对象	状态集合	关键限制
Task	draft / todo / active / awaiting_acceptance / done / cancelled / archived	boardColumn 为派生值，blocked 是可独立显示的运行障碍
Run	queued / running / waiting_input / pausing / paused / canceling / succeeded / failed / cancelled / interrupted	succeeded 表示本轮完成，Task Done 仍需当前验收
Attempt	pending / running / waiting_approval / succeeded / failed / cancelled / interrupted	每个节点 attemptNo 单调递增；与 leaseEpoch 绑定
Approval	pending / approved / rejected / expired / superseded	只能人类身份决定；自动过期不等于拒绝业务需求

TaskContract 已批准版本不可变。编辑产生新 revision；在同一事务中旧待审审批 superseded。运行中产生新 revision 时，禁止静默改变 Run：创建 pendingChange，按安全边界停止调度，用户选择重跑或搁置。

StepResult 包含 contractRevision、snapshotId、attemptId。Core 对照冻结 RunConfig 以及当前租约；不匹配返回 STALE_RESULT，保留审计但不触发状态变化。节点的自然语言总结永远不是门禁依据。

取消：先阻止新节点、发 cancel、等待 grace period；确认进程退出后释放写租约。若进程树无法确认终止，标 interrupted + quarantined workspace，不允许下一写入者占用。进程启动与命令结果丢失属于未知状态，不可盲目重跑。

审批哈希：canonical JSON 包含任务 revision、工作流 revision、requested capability、snapshotId 与 action 参数，使用 SHA-256；变化后 scopeHash 不同。过期/已经决定/设备撤销均拒绝旧批准，返回 409/403 并要求刷新。

modules · 模块全景与责任矩阵

以下 24 个模块构成完整产品。按功能边界划分，不代表 24 个服务；首版仍是单 Host 与本地数据库。独立包用于明确依赖与测试，不为拆分而拆分。

编号 / 模块	阶段	责任
M01 桌面壳与跨端客户端	P0 / P6	提供稳定 Windows/macOS 壳及可复用 Web UI；业务与 Electron 解耦。
M02 项目、环境与初始化检查	P1	连接本地 Git 仓库，显式记录可执行环境，不混淆阶段与环境。
M03 左侧自然语言入口与任务整理	P1	聊天是创建、澄清和控制任务的主入口，不是另一个无限聊天面板。
M04 Task Contract、版本与人类审批	P1 / P3	所有角色围绕同一批准版本工作，保留用户范围决定。
M05 看板、任务详情与自然语言控制	P1 / P6	清楚显示任务处在哪、为什么阻塞、谁需要行动。
M06 工作流模板、编辑器与编译器	P5	默认流程即用，高级用户可以配置同一执行定义。
M07 调度、Run、返工与恢复	P2 / P3	在有限预算内可靠推进流程，不靠模型文本改状态。
M08 插件注册、依赖与生命周期	P0 / P4	通过稳定契约替换能力，不把应用变成任意代码执行市场。
M09 执行器、模型与 Agent 配置	P2 / P4	Executor ≠ Model ≠ Profile ≠ Stage；只展示真实兼容组合。
M10 Git 工作区、快照与交接	P2 / P3	任务改动不污染用户正在编辑的主目录，审查对象可追溯。
M11 Review 与问题返工	P3	用独立上下文审查真实变更，问题必须可操作。
M12 验证、人工验收与交付	P3 / P6	自动检查与人类验收共同形成 Done，合并独立授权。
M13 运行观察、产物与成本	P2 / P6	用户看见真实动作、结果和阻塞，不展示伪造思维链。
M14 Context Builder 与基础 RAG	P5	让当前节点获取必要资料，明确来源、预算与可信等级。
M15 工作记忆、项目记忆与经验	P2 / P5 / P9	记住当前进度和已确认项目知识，不把模型推测当事实。
M16 工具服务、MCP 与配置	P4 / P9	给 Forge 自有 Agent 或支持扩展的外部执行器提供受控能力。
M17 安全、凭据与权限门禁	P0 / P4 / P6	在真实可执行边界内最小授权，诚实表达信任模式。
M18 持久化、事件、迁移与备份	P0 / P3 / P6	状态可恢复，数据库升级不毁掉任务和证据。
M19 命令、查询、事件与并发控制	P0 / P7	Desktop 和 Mobile 使用相同业务契约，权限在 Host 执行。
M20 远程 Host、配对与网关	P7	让手机连接在线电脑，远程处理而不是把桌面执行器塞进手机。

编号 / 模块	阶段	责任
M21 手机 Companion 与断线语义	P8	在手机上处理小而关键的决策，不复制桌面复杂编辑器。
M22 设计系统与无障碍	P0 / P6	打造有辨识度而不拥挤的产品工作台。
M23 设置、发布、更新与诊断	P6	形成可安装、可升级、可恢复的完整 Desktop 产品。
M24 Agent 评测与受控改进	P6 / P9	用证据检验规划、审查、交付是否比基线有价值。

M01 · 桌面壳与跨端客户端

落地阶段：P0 / P6。提供稳定 Windows/macOS 壳及可复用 Web UI；业务与 Electron 解耦。

边界	规格
输入	平台能力、当前 Host 连接、窗口布局偏好。
输出/拥有数据	窗口、托盘、菜单、窄 IPC 与 ForgeClient。

实现细节

main 使用 contextIsolation=true、sandbox=true、nodeIntegration=false；只加载打包的可信 UI。preload 不暴露 ipcRenderer/send 任意通道。固定方法、Zod/Schema 参数校验、senderFrame 来源检查。可疑导航与 window.open 默认阻断。[S01][S02]

异常、安全与恢复

Host 启动失败显示恢复页和诊断码；Renderer 崩溃可重载，但不能再次发 start 产生重复任务。应用退出发现运行中任务时提供“保持后台/安全停止/取消退出”。

完成条件与验证

T001-T005：无权限 IPC、第二实例、崩溃重载、快捷键、窗口尺寸与 DPI。

后续扩展

Mobile 使用同一 client 接口的 RemoteTransport，不 import Electron；后续独立 Linux Host。

M02 · 项目、环境与初始化检查

落地阶段：P1。连接本地 Git 仓库，显式记录可执行环境，不混淆阶段与环境。

边界	规格
输入	用户选择的真实路径、目标分支、启动/检查命令、SDK 可用性。
输出/拥有数据	Project、Environment、CommandPreset、TrustDecision。

实现细节

首先只读取 Git 状态与清单，不自动 npm install。命令存储 executable+argv+cwd+envRef+timeout，禁止模型生成字符串直接 shell:true。环境名 dev/test 是项目运行目标，Stage 是研发流程。初始化向导检验 Git、Node、包管理器、认证与工作目录空间。

异常、安全与恢复

脏主目录不被覆盖；无 Git 提供显式初始化按钮而非自动执行。路径中文/空格/大小写/符号链接正规化；Windows 路径与 WSL 路径不自动互换。

完成条件与验证

T006-T010：空路径、无 Git、脏树、符号链接越界、Windows 中文路径。

后续扩展

多根工作区、容器环境和远程项目目录后续增加；项目之间 credentials、memory 隔离。

M03 · 左侧自然语言入口与任务整理

落地阶段：P1。聊天是创建、澄清和控制任务的主入口，不是另一个无限聊天面板。

边界	规格
输入	自然语言、用户选定的项目上下文、允许读取的附件。
输出/拥有数据	TaskDraft、ClarificationQuestion、CommandProposal；引用原始 messageId。

实现细节

两步输出：意图分类（新需求/修订/查询/控制）→结构化 Draft 或命令提议。Schema 失败只允许最多 2 次修复，仍失败展示可编辑草稿。读项目工具只读且限量；模糊 scope 标记 proposed，不编造相关文件。批准按钮提交 frozen revision。

异常、安全与恢复

无模型/超时允许手工创建 TODO；失败保留输入。删除/暂停/合并等指令先生成可确认动作，不从聊天直接写状态。撤回只影响未批准草稿，已有任务保留来源。

完成条件与验证

T011-T015：歧义不自动填、JSON 损坏、重复提交去重、越权指令、手工降级。

后续扩展

语音输入、截图引导需求、批量任务与依赖草案；不将私人附件默认发送外部模型。

M04 · Task Contract、版本与人类审批

落地阶段：P1 / P3。所有角色围绕同一批准版本工作，保留用户范围决定。

边界	规格
输入	TaskContract、修订差异、审批请求与 CAS revision。
输出/拥有数据	不可变 task_revisions、approval、todo 转换事件。

实现细节

必填 title/goal/acceptance；每个验收项有稳定 ID、验证方法、required 和 sourceRefs。审批要求 openQuestions 为空或明确 deferred 且不影响范围；事务检查当前版本、scopeHash、身份与状态后写 approval+task+event。附件与规范也绑定版本/内容哈希。

异常、安全与恢复

并发编辑冲突 409；过期审批不复用；用户更改验收项使旧报告失效。取消不会删除历史。人工 waiver 不允许豁免安全硬约束，只能标明业务风险接受。

完成条件与验证

T016-T020：草稿不能开工、并发审批、变更失效、拒绝、来源可定位。

后续扩展

组织双人审批、模板与签署导出；目前单 Owner，但数据结构保留 actorId。

M05 · 看板、任务详情与自然语言控制

落地阶段：P1 / P6。清楚显示任务处在哪、为什么阻塞、谁需要行动。

边界	规格
输入	Task projection、Run、Approval、过滤器。
输出/拥有数据	卡片、列、任务详情、可撤销排序与命令反馈。

实现细节

默认 TODO/开发中/Review/验证/Done。Plan 映射开发列；条件节点不单独形成列。卡片显示当前阶段、executor、最近活动、阻塞理由与证据数量。拖拽跨列是语义命令，非任意 state PATCH；同列排序采用整数 position 并在事务中重排。

异常、安全与恢复

事件断流显示 stale 时间，不持续动画假装工作。列表可虚拟化；状态更新失败回滚 optimistic UI。Done 拖拽不满足门禁时给出缺失项。

完成条件与验证

T021-T025：越列拒绝、过滤器、事件去重、空状态、键盘移动与焦点。

后续扩展

Timeline/列表视图复用同一投影；高级多人排序再引入更复杂 rank 算法。

M06 · workflow模板、编辑器与编译器

落地阶段：P5。默认流程即用，高级用户可以配置同一执行定义。

边界	规格
输入	WorkflowDefinition、AgentProfile、插件 capability。
输出/拥有数据	不可变 WorkflowRevision、执行计划、编译错误。

实现细节

标准模板 plan→develop→review→verify→accept。正常 edges 是 DAG；返工用独立 reworkRoutes 定义、maxCycles 与总 attempt 上限。编译检查唯一节点/可达/缺绑定/能力/输出 Schema/失败出口/必需最终人类验收。条件只允许白名单字段与比较运算，不 eval 用户 JS。Vue Flow 仅编辑位置与连接。[S12]

异常、安全与恢复

保存草稿可有错误，发布不可。运行配置冻结，编辑新版本不修改当前 Run。主路径循环、无限返工、缺失插件都在执行前拒绝。

完成条件与验证

T026-T030：环/不可达/必需能力不匹配、旧 Run 冻结、条件边界。

后续扩展

P9 可加入只读 fan-out/join；并行写入需独立 worktree 与独立集成节点，不共享可写树。

M07 · 调度、Run、返工与恢复

落地阶段：P2 / P3。在有限预算内可靠推进流程，不靠模型文本改状态。

边界	规格
输入	已批准任务、编译流程、工作区租约、节点结果。
输出/拥有数据	RunConfigSnapshot、Attempts、Event、暂停/阻塞/结果。

实现细节

单 Host 调度串行，v1 默认每项目一个 active write Run。事务领取租约后递增 epoch，再启动执行器。节点重试仅用于明确的瞬时无副作用失败；代码返工走新 Attempt，并失效下游检查。连续相同问题到阈值升级人类。预算包括模型/工具/时间，上游未提供金额时显示 unknown。

异常、安全与恢复

重启读取未完成 Attempt：先核对 PID+start time+session（PID 可复用），能够原生恢复且一致才继续；否则 interrupted，保留 diff 并由用户选择新 Run。不要承诺 exactly-once 外部命令。

完成条件与验证

T031-T035：重复结果、旧 epoch、429、崩溃副作用未知、取消进程树。

后续扩展

多任务队列、配额与公平调度后续扩展；核心仍保持租约和版本门禁。

M08 · 插件注册、依赖与生命周期

落地阶段：P0 / P4。通过稳定契约替换能力，不把应用变成任意代码执行市场。

边界	规格
输入	Manifest、lock、配置、依赖服务和权限授予。
输出/拥有数据	已注册 capability、生命周期状态、禁用原因、兼容报告。

实现细节

加载顺序 discover→parse→compatibility→permission→resolve dependencies→activate→ready。每次 register 返回 Disposable；激活失败逆序释放已注册资源。停用先 draining，等待关联 Run 完成/取消后 dispose；运行中版本固定。内核白名单服务不可被普通插件覆盖。参考 Harness 的服务/生命周期思想，不照搬全部内核可替换的边界。[S06]

异常、安全与恢复

缺依赖/循环/重复 ID/不支持平台禁用插件，不拖垮 UI。v1 只加载随应用发布插件；开发者模式需确认信任，不宣传安全沙箱。升级后兼容失败可回滚插件版本，数据迁移另行处理。

完成条件与验证

T036-T040：泄露监听器、部分激活失败、升级运行冲突、恶意 Manifest、宿主崩溃。

后续扩展

签名扩展包、外部进程 RPC、有限 UI 插槽与第三方生态；不直接暴露数据库和系统凭据。

M09 · 执行器、模型与 Agent 配置

落地阶段：P2 / P4。Executor ≠ Model ≠ Profile ≠ Stage；只展示真实兼容组合。

边界	规格
输入	ExecutionRequest、ProfileRevision、credentialRef、能力探测。
输出/拥有数据	标准 ExecutorEvent、StepResult、原生 sessionRef 与 usage。

实现细节

第一执行器选 Codex SDK，第二选 Claude Agent SDK；SDK 与认证按 P0 实测版本锁定。Codex App Server 仅独立实验适配，不依赖其远程实验端口。模型目录从适配器能力返回；不硬编码万能“任意模型”。Claude SDK 默认官方 API Key，不擅自提供 claude.ai 订阅登录。[S07][S08][S09]

异常、安全与恢复

不支持交互审批的适配器拒绝需要该能力的 Profile。readOnlyEnforced=false 时不得启动要求强只读的节点，或显式切换受信任本地模式并撤回强隔离承诺。认证失效暂停，不回退到其他账户。

完成条件与验证

T041-T045：两个真实适配器契约一致、不可用模型、取消、结构化输出失败、认证错误。

后续扩展

协议型 ACP、更多 SDK；跨执行器恢复使用 Handoff 新会话，不移植私有会话文件。

M10 · Git 工作区、快照与交接

落地阶段：P2 / P3。任务改动不污染用户正在编辑的主目录，审查对象可追溯。

边界	规格
输入	repold、base ref、任务 ID、当前 lease。
输出/拥有数据	workspace lease、不可变 snapshot、diff、Handoff Bundle。

实现细节

工作区放 Host 私有目录下，用 git worktree add 创建受控分支。Git 命令使用 argv 和 -- 路径分隔，禁用未经授权 hook 执行；依赖安装先批准。开发结束验证 worktree clean/dirty，生成 commit/tree snapshot 并记录 content hash；Review 在新副本读取。快照包含新增文件但排除 secrets/node_modules。

异常、安全与恢复

原仓库脏树只提示不清理；主分支移动时合并前重新比较 base。Windows 锁文件、大小写冲突、长路径进入诊断；不使用 reset --hard 清理用户目录。Git worktree 不是沙箱。[S11]

完成条件与验证

T046–T050：一写入者、未跟踪文件、Git 注入、符号链接逃逸、分支移动。

后续扩展

多写入者仅独立树；集成节点合并候选后重新验证，不能沿用各分支测试证明合并版本通过。

M11 · Review 与问题返工

落地阶段：P3。用独立上下文审查真实变更，问题必须可操作。

边界	规格
输入	TaskContract、snapshot diff、项目规范、相关源码。
输出/拥有数据	ReviewReport、blocking/advisory issues、source anchor。

实现细节

默认不复制开发全部聊天，只提供结构化总结作为低信任线索。Issue 包含路径/行范围/原因/关联验收/建议验证，不能只写“优化性能”。Review 提出 approved 也要满足 schema、阻塞项清零、snapshot 绑定。写报告走 artifact API，禁止修改被审实现。

异常、安全与恢复

定位行号在新版发生变化时 anchor stale；模型不确定标 unverified。无法隔离只读时禁用强只读 Profile，不以提示词充当权限。用户接受建议不改需记录 waiver。

完成条件与验证

T051-T055：无证据阻塞、旧快照、越权写入、意见去重、豁免审计。

后续扩展

多个独立只读 Reviewer 可并行；汇总不按多数票证明正确，阻塞项由规则和人工决策。

M12 · 验证、人工验收与交付

落地阶段：P3 / P6。自动检查与人类验收共同形成 Done，合并独立授权。

边界	规格
输入	快照、CommandPreset、验收项与既有测试。
输出/拥有数据	VerificationReport、AcceptanceDecision、DeliverySummary、可选 MergeOperation。

实现细节

命令验证器执行用户确认的 typecheck/build/test 配置，记录 exitCode、stdout/stderr、报告文件与超时。没有测试框架显示 not_configured，转人工验收，不能编造 pass。每个 required criterion 对应证据或人工决策。accept 检查当前 snapshot 和全部硬门禁；合并前检查 base 并二次确认。

异常、安全与恢复

环境失败与业务测试失败区分；测试本身写临时目录允许，但验收来源不可改。自动修复测试断言需提变更，不能删失败用例。合并副作用先写 intent，执行后 reconcile 防重复。

完成条件与验证

T056-T060：无测试、伪报告、日志中 pass 但 exit 非 0、版本漂移、合并重复。

后续扩展

浏览器验证、安全扫描作为独立插件接口；当前仅既有检查，不引入其他测试产品实现。

M13 · 运行观察、产物与成本

落地阶段：P2 / P6。用户看见真实动作、结果和阻塞，不展示伪造思维链。

边界	规格
输入	标准事件、日志流、artifact bytes、usage。
输出/拥有数据	时间线、Diff、上下文清单、报告、成本摘要与导出。

实现细节

低频业务事件持久化并带 seq；高频 token delta 合并 50-100ms 刷新，掉线补日志不重放副作用。日志按文件分段，DB 保存索引；artifact 内容 hash、MIME、size、快照与脱敏版本。金额仅来自 usage 或标注估算的价格配置；缺失字段用 unknown 非 0。

异常、安全与恢复

超大日志截断提示并允许局部查看；恶意 Markdown/HTML 不运行脚本；报告外链需确认。清理原文后保留墓碑和不可用标识，不让旧引用看似仍有效。

完成条件与验证

T061-T065：重连乱序、脱敏、日志过载、恶意 HTML、未知成本。

后续扩展

OTel 导出可后做；默认遥测关闭，诊断包导出前用户可预览。

M14 · Context Builder 与基础 RAG

落地阶段：P5。让当前节点获取必要资料，明确来源、预算与可信等级。

边界	规格
输入	Task、角色、查询、项目白名单文档、snapshot。
输出/拥有数据	ContextBundle 与 item 来源、预算、冲突标记。

实现细节

优先顺序：已批准合同/政策→人工决定→当前快照→版本匹配项目规则→历史参考。文档按标题/代码块结构切分，保留原文定位和 hash；先 projectId/env/version 过滤再检索。首版 FTS5+显式中文分词/字符索引测试，不能假设默认分词正确。[S15]

异常、安全与恢复

无答案返回 empty，不补写规则；两版本冲突请求确认。删除文档原子撤销索引/缓存，冻结 Run 保留脱敏证据副本并说明来源已撤销。凭据不入索引。

完成条件与验证

T066-T070：跨项目泄漏、冲突、删除撤回、中文代码混检、引用不存在。

后续扩展

向量与 RRF 混合检索后续；先用标注集证明检索改善，不强制首版向量数据库。

M15 · 工作记忆、项目记忆与经验

落地阶段：P2 / P5 / P9。记住当前进度和已确认项目知识，不把模型推测当事实。

边界	规格
输入	运行状态、用户决定、验证报告、历史反馈。
输出/拥有数据	WorkingState、ProjectMemory 候选/确认/过期/撤销、经验记录。

实现细节

工作记忆是结构化 DB 状态和 checkpoint，P2 必做。项目记忆包含事实、sourceRefs、lastVerified、scope、expiresAt，写入先 candidate，人类确认或明确自动校验后 validated。跨项目经验默认关闭，只分享脱敏规则而非代码。

异常、安全与恢复

旧 API/路径随项目 revision 变为 stale；当前观察冲突优先实时事实并提示。记忆不代替 Git/账本/运行状态；删除同步缓存与 embedding。

完成条件与验证

T071-T075：候选不可当验收、过期失效、项目隔离、冲突反馈、删除。

后续扩展

经验→候选策略→固定数据集评测→人审→灰度→回滚。禁改权限、验收和隐藏测试。

M16 · 工具服务、MCP 与配置

落地阶段：P4 / P9。给 Forge 自有 Agent 或支持扩展的外部执行器提供受控能力。

边界	规格
输入	工具 Manifest、参数 Schema、角色权限、运行范围。
输出/拥有数据	ToolResult、审批请求、脱敏事件。

实现细节

MCP 仅一个适配器：发现工具后标准化输入/输出/副作用分类；外部执行器是否可接入由 capabilities 决定。结果标不可信，不能接受其中“忽略上文/已批准”等指令。超时/大小限制/源域限制在 Host 工具网关执行。[S16]

异常、安全与恢复

工具注册名称冲突拒绝激活；Server 离线不崩溃，返回明确错误。看似只读工具也可能外发数据，必须声明网络与凭据范围。

完成条件与验证

T076-T080：参数非法、提示注入、超时、越权、注册冲突。

后续扩展

第三方扩展运行隔离是独立工程，不使用 MCP 本身作为安全证明。

M17 · 安全、凭据与权限门禁

落地阶段：P0 / P4 / P6。在真实可执行边界内最小授权，诚实表达信任模式。

边界	规格
输入	PolicyProfile、身份、requested permissions、secret refs。
输出/拥有数据	有效权限交集、Approval、Audit、脱敏内容。

实现细节

有效权限=宿主政策∩项目授权∩节点授权∩执行器可执行限制。v1 只允许可信本地仓库与内置插件；强隔离能力缺失则阻断所需模式。safeStorage 仅保管本地密文，Main 凭据代理按 adapter/profile 授予，Renderer 拿不到明文。[S02][S03]

异常、安全与恢复

repo 脚本、install hooks、Agent shell 都属于潜在任意代码；禁止描述 trusted-local 为安全沙箱。恶意插件同用户进程可读文件的风险必须在开发者模式告知。预览独立 webContents 无 preload 无 Node。

完成条件与验证

T081-T085：CredentialRef 伪造、IPC 发件人、越域预览、secret 脱敏、权限扩大。

后续扩展

OS 级执行沙箱、企业策略和第三方包签名后续评估；安装审核不等于绝对安全。

M18 · 持久化、事件、迁移与备份

落地阶段：P0 / P3 / P6。状态可恢复，数据库升级不毁掉任务和证据。

边界	规格
输入	Domain command、事务、artifact 索引、迁移版本。
输出/拥有数据	SQLite 关系表、append-only event、snapshot、备份。

实现细节

Host 单写入者；事务同时提交 aggregate revision 与事件。WAL 与 busy_timeout 启用，数据库位于本地用户数据目录，不放网络共享盘；备份使用 SQLite 备份接口/一致性 snapshot，不只复制活跃 db 漏掉 WAL。
[S14]

异常、安全与恢复

迁移前备份与磁盘检查；失败保留旧库只读并阻止新写入。最低兼容 schema 超前时旧版不打开。插件私有数据按 namespace 隔离且不持有核心连接。

完成条件与验证

T086-T090：断电事务、WAL 备份、迁移失败、磁盘满、插件跨 namespace。

后续扩展

云同步不是文件拷贝；远程控制使用单 Host 事实源，不同步多个可写 SQLite。

M19 · 命令、查询、事件与并发控制

落地阶段：P0 / P7。Desktop 和 Mobile 使用相同业务契约，权限在 Host 执行。

边界	规格
输入	CommandEnvelope、Query、事件游标、认证上下文。
输出/拥有数据	统一结果/错误、event stream、资源版本。

实现细节

客户端只提交业务参数；actor、scopes 由传输认证注入。所有写命令带 idempotencyKey 和 expectedRevision；同 key 不同 payload 返回冲突，同 key 同 payload 返回原结果。审批与 start 等敏感写入先持久化 receipt 后提交副作用。

异常、安全与恢复

无匹配方法拒绝；不提供 executeSql 或任意 shell RPC。事件至少一次投递，客户端按 seq 去重；游标超出保留范围先拿 snapshot 再继续订阅。

完成条件与验证

T091-T095：伪 actor、idempotency 冲突、CAS 并发、游标缺口、未知命令。

后续扩展

HTTP/SSE 网关只翻译 transport，不能再实现一套审批和状态机。

M20 · 远程 Host、配对与网关

落地阶段：P7。让手机连接在线电脑，远程处理而不是把桌面执行器塞进手机。

边界	规格
输入	Host 设置、TLS 入口、设备配对、本地审批。
输出/拥有数据	设备会话、项目 scopes、SSE 事件、远程命令。

实现细节

默认关闭远程；初版 127.0.0.1 网关+用户配置的私网 HTTPS 入口（例如 Tailscale Serve）。PWA 与 API 同源。一次性高熵配对 nonce 放 URL fragment、10 分钟失效，本地确认设备后创建 Secure/HttpOnly/SameSite cookie session。nonce 交换后立即移除 fragment。[S18]

异常、安全与恢复

TLS 仅保护传输；网关不做自称 E2EE。配对尝试限流，撤销设备立即关闭流并拒绝新命令。远端默认只允许读/草稿/审批/开始/暂停/取消，不允许装插件、改凭据、任意终端。

完成条件与验证

T096-T100：nonce 重放、设备撤销、Origin/CSRF、权限缩小、睡眠离线。

后续扩展

公网 Relay 需单独威胁建模和运营；不在 v1.1 将裸 Host 或 Codex 端口映射公网。

M21 · 手机 Companion 与断线语义

落地阶段：P8。在手机上处理小而关键的决策，不复制桌面复杂编辑器。

边界	规格
输入	远程项目、任务、待批准项、流式摘要。
输出/拥有数据	任务 Inbox、详情、审批、聊天补充、Host 状态。

实现细节

Vue 响应式 PWA：首页优先待我处理；底部任务/收件箱/主机/设置。详情先摘要、再 diff 与证据；审批前强制刷新 scopeHash 与 snapshot。危险写入需二次确认。离线只缓存脱敏只读快照和本地草稿，禁止 service worker 后台重放审批。

异常、安全与恢复

手机页面关闭不停止 Host Run；网络恢复显示“数据更新于”，收到服务端确认才算操作成功。手机不是通知可靠送达保证，首次版本无推送仍可轮询。

完成条件与验证

T101-T105：离线不可批、旧快照、两设备冲突、竖横屏、弱网重连。

后续扩展

Capacitor 封装复用业务层并分别做安全存储/推送/商店审核；仍由远程主机执行。[S05]

M22 · 设计系统与无障碍

落地阶段：P0 / P6。打造有辨识度而不拥挤的产品工作台。

边界	规格
输入	Tokens、布局断点、组件状态、键盘映射。
输出/拥有数据	统一组件、页面、亮暗主题与可读性检查。

实现细节

采用“石墨导航+暖白内容+铜橙动作线”的 Editorial Workbench。强调任务合同、动作与证据，不堆霓虹/机器人。Reka UI 用于对话框/菜单焦点管理；样式由 Forge 定义。[S13]

异常、安全与恢复

最小宽 1280 不压缩到五列不可读，改水平滚动；错误不只颜色表达。动画尊重 reduced-motion；所有加载有结束和错误状态。

完成条件与验证

T106–T110：tab 顺序、对比度、125/150%DPI、中文长文、减少动画。

后续扩展

主题扩展仅 Tokens；插件不注入全局 CSS、不改全局导航和核心审批样式。

M23 · 设置、发布、更新与诊断

落地阶段：P6。形成可安装、可升级、可恢复的完整 Desktop 产品。

边界	规格
输入	设置、签名材料、CI 平台、版本 manifest。
输出/拥有数据	安装包、更新包、迁移、诊断与退出行为。

实现细节

Mac arm64/x64 分别构建签名公证；Windows x64 安装包签名，检查 SmartScreen 表现但不保证签名就消除所有警告。原生 SQLite/PTY 对每个 ABI 构建；首次启动从空用户目录验证。更新前暂停新任务、等待安全点，备份库再更新。[S19][S20]

异常、安全与恢复

无签名凭据只产内部测试包，不能标正式发布。签名密钥不得进源码。回滚应用若 schema 不兼容，使用配套备份或只读恢复，不能强开旧库。

完成条件与验证

T111-T115：安装卸载、升级、密钥迁移、主机退出、脱敏诊断。

后续扩展

Linux 发行、自动更新服务器、企业代理支持分开规划；品牌名 Forge 尚未作商标/域名清查。

M24 · Agent 评测与受控改进

落地阶段：P6 / P9。用证据检验规划、审查、交付是否比基线有价值。

边界	规格
输入	固定任务集、正常/缺陷样例、人工标签、模型预算。
输出/拥有数据	对照报告、错误分类、候选 Prompt/策略 patch。

实现细节

三层评测：契约/状态确定性测试；可控 SDK 回放；真实模型多次运行。统计 task 成功、错误 Done、人工次数、返工、成本与拒绝率；不可只优化通过率。隐藏验收与开发上下文隔离，固定数据集版本。

异常、安全与恢复

运行过多调参污染测试集需新 holdout；策略无显著收益则不升级。任何改进不能放宽权限、修改已批准验收或自动开新工具。

完成条件与验证

T116-T120：基线公平、隐藏数据泄漏、坏策略回滚、预算、取消误记成功。

后续扩展

候选→离线评测→人工批准→少量新 Run→监测→回滚；这是应用策略迭代，不等于底层模型训练。

09 · 插件契约与装配规则

Manifest 的 schemaVersion 是 Forge 契约版本；version 是插件版本；forgeApiRange 控制兼容；supportedPlatforms 是声明而非验证。实际可用性还需 probe 返回 SDK/CLI 版本、认证、readOnly、取消与恢复能力。公共定义见 contracts/plugin-manifest.schema.json 与 plugin-api.ts。

扩展点	宿主提供	插件只能返回
Executor	工作区租约、ContextBundle 引用、凭据引用、AbortSignal	事件、产物引用、结果；不能修改 Task 状态
ModelProvider	格式/预算/超时/认证引用	文本流/结构化结果/usage；工具写入另过门禁
ContextProvider	项目过滤与查询预算	带 source/hash/trust 的 items
Tool	输入 Schema、PolicyDecision、执行范围	工具结果与副作用记录
Verifier	冻结 snapshot、验收项和命令配置	检查结果与证据
UI 贡献	类型化卡片/配置 Schema/产物 renderer slots	v1 只声明式；不执行任意远程 JS

生命周期：发现清单时不执行 entry；兼容与授权后才 import。激活注册动作写入 scope 栈，失败逆序 dispose。多插件同名服务拒绝启动。构造依赖有向图并拒绝环。作用域为 host/project/run 三层，明确实例数与释放时间。

内置插件可进 Host 但受模块约束；这不是抵御恶意代码。第三方插件未来单独进程走显式 RPC，其服务 ID 与 token 按实例授予；进程隔离只降低崩溃影响，OS 安全沙箱另做。

运行配置保存所有插件版本、profileRevision 和配置 hash。更新建立新 version，不热换活跃 Run；插件停用后已完成 artifact 仍能通用 JSON/Markdown 查看。禁止直接注册“修改审批/跳过 Done 门禁”类服务。

10 · workflow 执行伪代码与返工语义

```

on StartTask(command):
  authenticate actor; authorize task:start
  BEGIN IMMEDIATE
  assert revision == expectedRevision
  assert approved contract and no active write run
  insert command receipt + frozen run config
  insert run(queued) + event
  COMMIT

on ScheduleNext(run):
  select ready node from compiled normal DAG
  acquire workspace lease; increment epoch
  create attempt; persist launch intent
  start adapter outside transaction

on Result(attempt, result):
  validate schema, epoch, snapshot, contract version
  persist result + artifacts in transaction
  if blocking outcome: bounded rework or escalate
  else evaluate deterministic exit guards
  append event; schedule next

on AcceptTask(approval):
  re-read current revision and scope hash
  assert required evidence/manual decisions current
  atomically accept snapshot + mark task done

```

关键：DB 事务不可跨模型网络调用。Attempt 启动前记 intent，启动后记 handle；崩溃落在两者之间需要 reconcile 而不是立即重新启动。所有 adapter completion 必须关联 attempt 与 epoch；过期回包只进审计。

重试与返工不同：网络 429 没有动作可有限退避重试；代码变更后的测试失败创建新开发 Attempt。返工轮次跨 Review/Verify 共享 maxTotalAttempts，不允许在两个节点间分别计数绕过全局上限。

正常路径为 DAG；reworkRoutes 不参与拓扑排序，但必须指向可重入节点。每轮新 snapshot 使相应后继评审失效；输出已通过也不能复用不同快照结果。

11 · 快照、验收与副作用恢复算法

快照算法：确认写执行器结束→获取租约→git status --porcelain -z→扫描排除敏感路径→生成只包含允许文件的 tree/commit→记录 parent/base 与 contentHash→原子发布 CodeSnapshot。没有变化时结果允许 no_change，但需要解释并验证；不能伪造 diff。

Review 不应在开发正在变化的目录读取。使用指定 snapshot 新建只读审查副本；运行构建/测试可在临时工作副本产生 cache/dist，但验证结束后比对源文件 tree 未变。所谓只读既包括权限能力，也包括运行前后完整性检查；后者只能发现违规不能阻止恶意逃逸，界面必须准确标明模式。

操作	安全策略	恢复规则
安装依赖	先展示命令、registry、脚本执行风险；批准后运行	可能副作用未知则询问，不能自动清理系统
运行测试	基于批准 CommandPreset 和 snapshot	保留报告；仅明确无副作用瞬时错误可重试
创建本地提交	写入 Operation 记录、预期 parent/tree	恢复查分支/commit/tree，不重复提交
合并	人审绑定 targetHead 与 sourceSnapshot	目标变化则重验；失败保留冲突，不自动 force
清理 worktree	无有效 Run/lease 且用户确认保留策略	仅清理 Forge 拥有目录，绝不清主工作区

安全验收不可豁免；业务验收可由人显式接受风险，但必须显示“未验证，由用户接受”，不能成为自动 pass。每个必要验收项的证据可打开对应报告、代码或人工决定。

12 · 数据库与接口实施约定

contracts/schema.sql 是可执行 DDL 基线，包含用户、项目、环境、草稿消息、任务 revision、审批、 workflow/profile 版本、Run/Attempt、租约、快照、artifact、Review、验证、context/memory、设备 session、事件和副作用账本。ORM 迁移必须与该约束一致。

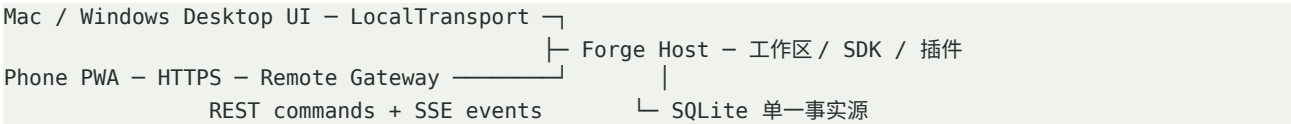
时间存 UTC ISO 8601；展示按用户时区。ID 用 UUIDv7/ULID 一类可排序 ID，不依赖数据库自增对外暴露顺序。金额用 minor unit 并绑定 currency；usage 缺失允许 NULL。大型日志与报告文件存于 Host data 目录，数据库只存索引/hash；禁止用户输入直接拼文件路径。

API 采用 CommandBus+QueryService；本地 IPC 和远端 HTTP 共用处理器。contracts/openapi.yaml 规定远端入口，method payload 逐项校验。业务错误统一：code、message、retryable、correlationId、currentRevision、details；日志脱敏。

错误码	HTTP/行为
VALIDATION_ERROR	400；展示具体字段
UNAUTHENTICATED / FORBIDDEN	401/403；拒绝并清除失效会话
REVISION_CONFLICT / STALE_APPROVAL	409；刷新对象，不自动重发批准
CAPABILITY_UNSUPPORTED	422；调整配置或更换执行器
HOST_BUSY / RATE_LIMITED	429；带 Retry-After，有限退避
UPSTREAM_ERROR / TIMEOUT	502/504；保留 Attempt 与错误来源
WORKSPACE_QUARANTINED	409；等待人工处理不可启动新写入

事件 seq 全 Host 递增，客户端按 project 过滤后可有 seq 间隔，不把非连续数字误判漏消息。服务器另给 cursor 水位；过旧游标返回 resync_required。审计 actor 由 Host 注入，不接受 payload 冒充 human。状态词必须按 Schema 映射：UI “未执行/需人工” 均对应 verification unverified，人工接受风险在数据库为 waived 且不等同 pass；UI 记忆 “已过期” 对应 stale 并带 expiresAt。canceling 是真实 Run 状态；reconcile_required 是 interrupted 的原因，不新增未定义状态。计划和审批节点分别使用 plan-result 与 approval-decision schema。

13 · 远程与移动架构：不是同步两份开发环境



Remote Gateway 是同一个 CommandService 的传输适配器。它不是独立 workflow 引擎，也不把本地 SQLite 同步到手机。代码、执行器认证、Git workspace 和模型 key 留在 Host；手机按范围读取需要的 diff/摘要，发送命令。

P7 第一形态是电脑 Forge 仍在托盘运行并提供网关。无需窗口常开，但系统不能睡眠；退出应用意味着 Host 离线。设置提供“运行中阻止空闲睡眠”的明确开关，不保证断电后继续工作。独立服务安装、NAS 无头运行放 P9。

RemoteTransport 只能使用配对后的 HTTPS 同源服务。网关默认绑定 127.0.0.1，推荐用户配置私有网络 HTTPS 入口，说明需要手机也能加入该网络。Tailscale Serve 是可选入口方案，不是应用认证替代。[S18]

v1.1 不做端口直通公网，不公开裸编程 SDK/App Server，不把 SSH 私钥发给手机，不借 PWA service worker 运行编程命令。没有账户和证书时不能演示一个“伪远端成功”。

14 · 配对、会话、远程授权与离线状态

环节	必须实现
创建配对	仅本地主机 UI 可开启；随机 nonce 至少 128 位；10 分钟一次性；存 hash
扫描/输入	QR 只含 HTTPS origin + fragment nonce；交换后立即移除 fragment；不带长期 token
确认设备	手机显示待确认；本机显示设备名/地址/指纹摘要；本地人工批准 project scope
会话	同源 Secure HttpOnly SameSite=Strict cookie；短会话+有界刷新；服务端存 token hash
写操作	Origin 校验+session-bound CSRF token；每次验证 scope、revision、资源归属和幂等 key
撤销	撤销 device/session，关闭 SSE，下一请求 403；不自动取消已经确认发生的操作
离线	只读缓存标最后更新时间；消息草稿可离线保存，审批/开始/合并绝不排队自动发送

远端默认权限：project:read、task:draft、task:approve、run:start、run:pause、run:cancel、acceptance:decide；不授予 plugin:install、credentials:write、shell:any、remote:pair。远程合并默认禁用，未来需单独策略与再次确认。

SSE 通过同源 cookie 认证，Last-Event-ID 或服务端 cursor 恢复。连接建立和每次敏感事件交付都检查设备状态；反向代理关闭缓冲并设置心跳；手机切后台按重新连接处理。对跨来源与实时连接要同样做认证、Origin 和消息授权，不能认为连上之后永久可信。[S17]

缓存不得含 key、原始认证文件、敏感日志或全量代码；只缓存明确可查看数据并提供清除按钮。通知初版可省略，后续推送只放 taskId 与简短状态，不把源码放在锁屏。

配对交换细节：nonce 仅用于 claim，返回独立高熵 claimSecret 并只存其 hash；status 轮询不能使用公开 pairingId 换取会话。批准后只在首次成功交付时建立会话；交付回执丢失优先凭已写 cookie 查询 session，若确实无 cookie 则回本机重新配对，不重复凭已消费 secret 发新会话。所有 claim/status 请求严格同源 Origin、限速和过期校验。

15 · 安全威胁模型与禁止事项

威胁	默认控制	剩余风险/限制
恶意仓库脚本	初次信任确认、命令批准、执行器限制与环境记录	trusted-local 不是恶意代码沙箱
插件偷权限	内置白名单、Manifest 审核、核心接口封装	同进程可信插件仍拥有进程权限；第三方不默认允许
提示注入	外部文字标不可信、工具参数校验、核心授权独立	模型仍可能提出坏建议，需要门禁与证据
预览页面攻壳	独立 WebContentsView、无 preload/Node、导航权限限制	网页预览仍可能访问网络，按环境范围限制
远程窃取控制	私网 HTTPS、设备配对、CSRF、scope 与撤销	不保证被完全控制的同用户宿主仍安全
日志泄密	凭据 ref、字段脱敏、导出预览、保留策略	用户代码自身可能含密钥，扫描与最小上下文仍必要

不允许：模型输出 shell 字符串直接作为系统命令；以文本“用户同意”构造 Approval；用 window.ipc 任意通道；将 Auth 文件复制进 artifact；插件覆盖 Task/Approval 服务；失败后用 danger-full-access 自动重试；清理失败用 rm -rf 用户根目录。

双层政策：Kernel 负责自己能控制的命令和资源；外部 Coding Agent 还需其真实 sandbox/approval 机制。能力矩阵里必须区分“enforced”“检测到”“仅提示约束”。要求无法满足时阻止运行，不能静默降级。

同用户恶意软件、管理员控制主机、硬件物理攻击不在首版可保证安全边界内。远程公网 Relay 和任意第三方插件必须追加威胁建模与安全审计后再开放。

16 · 非功能目标、测试策略与发布门禁

目标	规划阈值（待 P0 测量校准）	测量方法
首次窗口可交互	目标≤3 秒，不包括模型/登录耗时	生产包冷启动，Mac/Windows 各重复 10 次
普通命令反馈	本地 p95≤200ms；长操作立即回 operationId	固定本地 fixture、禁模型混入延迟
界面性能	1000 任务不卡死；可见列表虚拟化	1600×1000，流式事件 100 条/秒负载
状态恢复	崩溃后不丢已提交审批/结果	注入崩溃点与事务重放测试
内存/CPU	记录 idle/1 active run 基线，不给无测量承诺	区分 Forge 与执行器/项目 build 资源
远端	断流重连后状态一致，旧审批 0 成功	弱网、两个设备、Host 重启测试

测试层次：纯 Core/Schema/状态机 unit；SQLite/Git/插件 host integration；契约录制 replay；真实模型 smoke；Desktop UI E2E；安装/签名/升级实机；远端认证与移动端弱网。Playwright Electron 接口为实验性，测试工具版本固定并保留原生安装手动清单。[S21]

正式 Desktop v1.0：P0-P6 全部 required 任务通过；没有未关闭严重安全与数据损坏缺陷；至少两个真实执行器完成同一验收样例；Mac 与 Windows 支持组合各跑完一次人工验收；演示数据/Mock 不计通过。

Agent 评测另设独立结果：固定小型仓库与任务集、带隐藏条件、重复 3-5 次记录波动；数据不足时仅描述样本结果。功能测试通过不等于 Agent 普遍可靠，模型评测也不能替代权限/事务单元测试。

本交付包仅执行契约静态校验、DDL 与 HTML 原型冒烟；120 条 T 编号是产品待实现测试规格。不得把本交付包的通过状态解读为完整 Forge 产品在 macOS/Windows 已测试通过。

17 · Desktop 与手机设计系统

设计方向：Editorial Workbench。不是办公室游戏，也不是几个终端拼盘。深石墨导航、暖白画布、铜橙行动强调；主要空间给任务、代码和证据，左侧自然语言入口始终能回到原始意图。

design/index.html 为可点击高保真原型。图片均由该原型实际渲染，全部运行数据为示例；尚未连接 Host 或调用模型。原型用于说明视觉与交互，生产须重新实现为类型化 Vue 组件。

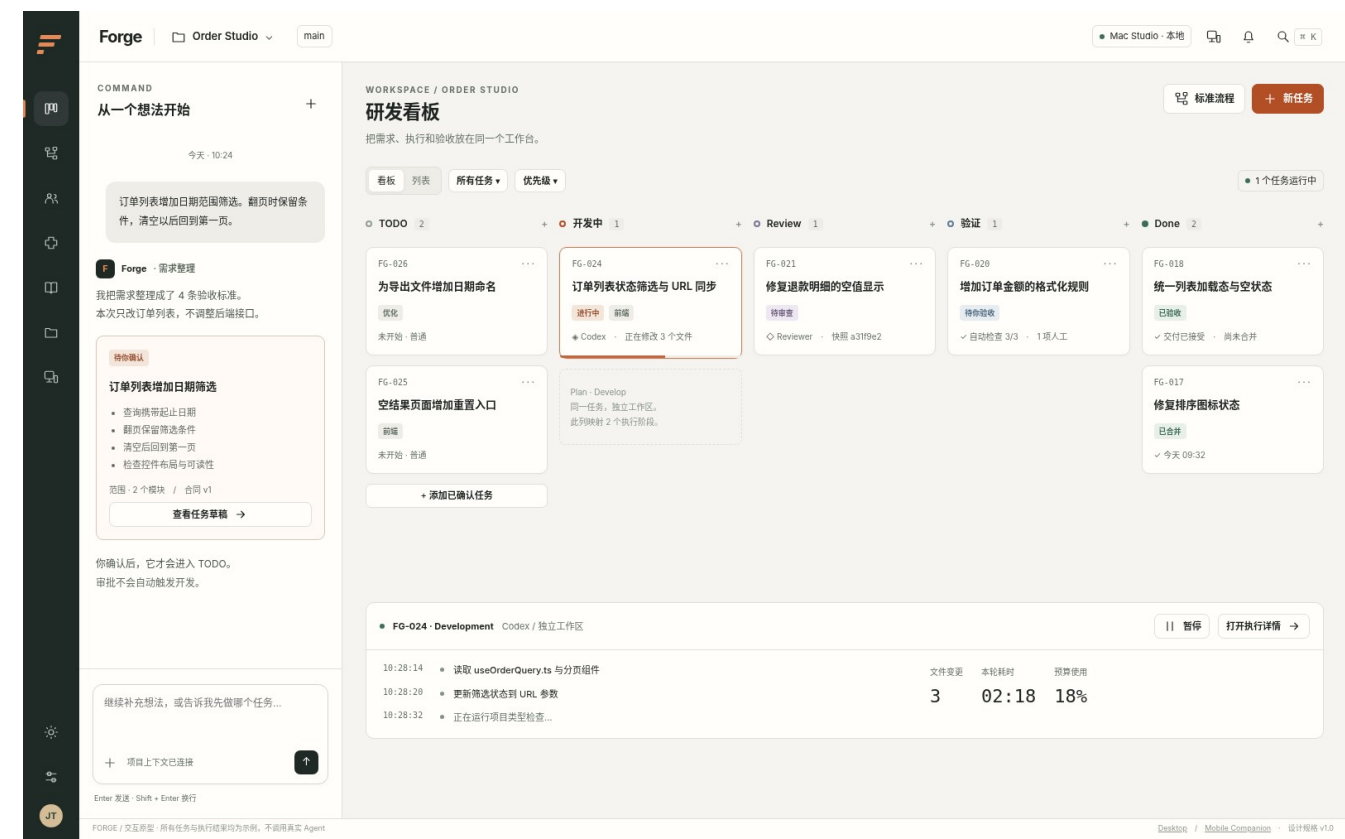


图 1 · Desktop 首页：左侧聊天与待批准草稿，右侧真实状态看板及当前执行摘要。

维度	规范
窗口	参考 1600×1000；最小 1280×800。1440 以下优先折叠非核心详情，卡片不无限压缩。
布局	侧轨 68、标题栏 62、聊天 318 可调宽、主区边距 28；卡片最小 186，横向溢出可滚动。
文字	生产正文 14、次级 12、标题 24；系统字体；代码等宽。平台 DPI 与中文换行需实测。
颜色	背景 #F5F4F0；导航 #1F2926；强调 #B34F27；正文 #202522；次级 #657066。
层级	任务状态不只用颜色；每项危险动作有文本、范围、版本和明确确认。
交互	120-180ms；支持 reduced motion；完整键盘焦点；手机目标至少 44px。
组件	Reka UI 基础交互+自有 tokens；Vue Flow 只承担高级画布。[S12][S13]

全部页面规格在 design/page-specs.json；设计 Token 在 design/tokens.json。原型中按钮的提示性 toast 不等于生产功能已实现。正式页面必须具备 loading、empty、error、stale、offline 与 unauthorized 状态。

18 · 页面、动作与接口总表

页面	主要目的	阶段
D01 研发看板	让用户同时表达需求、查看执行，并知道下一项需要自己做的决定。	P1 / P6
D02 任务草稿与审批	把模糊意图转成双方确认的可执行约定，审批与开工分离。	P1
D03 任务详情与交付历史	用一份任务页面串起原始意图、当前合同、执行、决策和最终代码。	P1 / P3
D04 执行观察与控制	只展示真实动作、产物与可核查摘要；提供可靠的停止、恢复和排障入口。	P2 / P3
D05 Review 与代码证据	让审查判断绑定需求版本和代码快照，而不是绑定开发者的完成声明。	P3
D06 验证与人工交付验收	逐条验收并区分构建通过、需求通过与最终交付接受。	P3 / P6
D07 workflow 模板库	默认可用，但不限制用户只能使用固定研发流程。	P5
D08 workflow 编排器	以同一份声明式定义支撑表单编排与高级画布，不维护两套引擎。	P5
D09 Agent 角色库	把角色、执行器、模型和权限分开配置，而不是给一个模型取几个名字。	P4
D10 角色与执行器配置	使角色配置可审阅、可版本化，并显式说明底层执行限制。	P4
D11 插件管理	展示贡献点、权限和生命周期；首版只启用随应用发布的可信内置插件。	P4
D12 项目知识与记忆	明确 Agent 参考了什么、哪些事实已确认、哪些只是候选经验。	P5
D13 项目与环境设置	以显式授权的仓库与命令建立可运行环境，不让聊天指定任意宿主路径。	P1 / P6
D14 远程连接与设备	将同一 Host 安全暴露给用户自己的手机；默认不开远程服务。	P7
D15 应用设置、诊断与更新	建立日常可使用、可恢复和可安全升级的桌面体验。	P6
MOB01 手机待办与审批收件箱	优先显示需要人处理的事情，而不是缩小的五列看板。	P8
MOB02 手机任务与实时进度	离开电脑时了解执行并处理合理的暂停/澄清，不提供任意远程 Shell。	P8
MOB03 手机版本化审批	确认明确的任务版本或交付快照；在小屏上保留必要的风险与范围信息。	P8

路由名使用设计原型的 hash 命名；实际 Router 可以使用/projects/:id 路径，但每个设计页面都必须有对应组件、状态和测试。API 字段以 contracts/openapi.yaml 及命令目录为准。

D01 · 研发看板

页面 D01 · 路由 #board · 阶段 P1 / P6 · 模块 M03,M05,M13

页面目的

让用户同时表达需求、查看执行，并知道下一项需要自己做的决定。

布局与组件

左轨导航；顶部项目/分支/Host 状态；318px 可折叠聊天；五列看板；底部当前 Run 摘要。

字段与信息层级

卡片：编号、标题、业务类型、状态文本、当前执行器、阻塞标记、已接受/已合并标记。不按时间伪造完成百分比。

操作与流转

创建/编辑草稿；选择已批准 TODO 开始；点击卡片进入详情；拖动只发 Command 并验证门禁；批量启动后置。

异常与限制

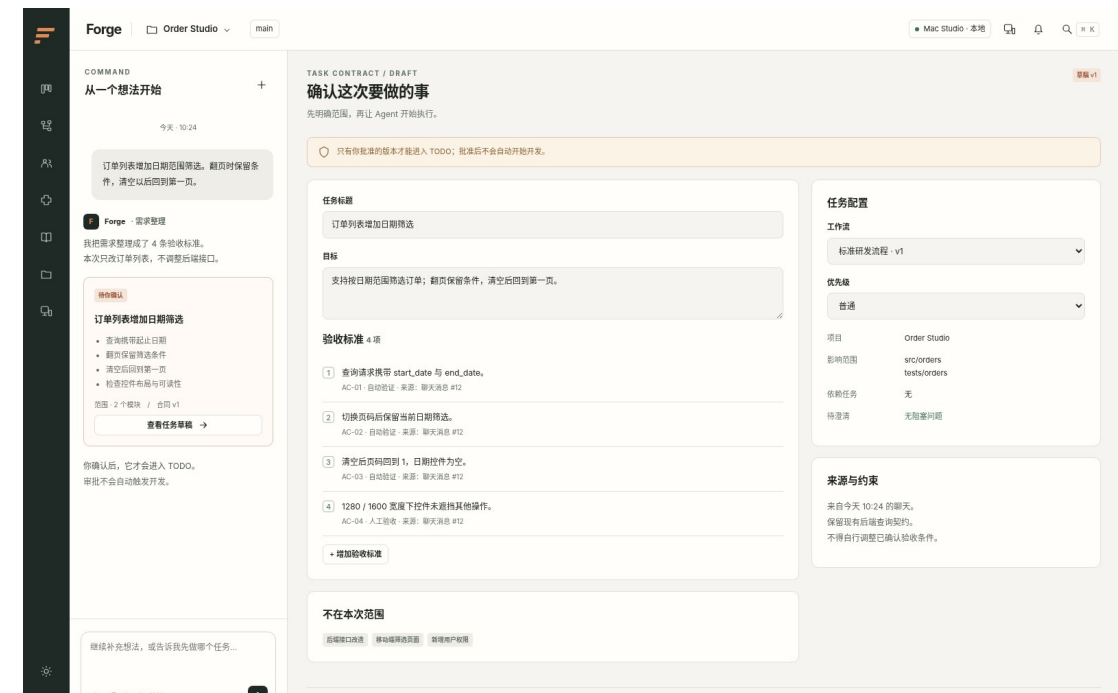
空项目显示选择仓库；无任务提供示例输入；Host 掉线整板只读并显示最后同步时间；启动失败留在可重试状态。

接口与命令

projects 查询、board 查询、runs.start/tasks.reorder；conversations.send；event cursor。

D02 · 任务草稿与审批

页面 D02 · 路由 #draft · 阶段 P1 · 模块 M03,M04



任务草稿与审批 · 交互原型示意

页面目的

把模糊意图转成双方确认的可执行约定，审批与开工分离。

布局与组件

左侧保留原话与澄清；主区可编辑 Goal、Acceptance、Scope；右区流程、优先级、依赖与审批对象。底部固定审批栏。

字段与信息层级

title、type、goal、acceptance[id,text,verification]、constraints、scope、outOfScope、openQuestions、sourceRefs、workflowRef。

操作与流转

增删验收项；回复未解问题；保存草稿 revision+1；预览 diff；批准当前 revision 进入 TODO；不得替用户默认排除后端改造。

异常与限制

有关键未解问题时批准禁用；保存冲突显示两版本；模型失败保留用户草稿；审批过期强制刷新再确认。

接口与命令

tasks.revise/tasks.approve；TaskContractSchema；If revision/CAS。

D03 · 任务详情与交付历史

页面 D03 · 路由 #task · 阶段 P1 / P3 · 模块 M04,M05,M10

页面目的

用一份任务页面串起原始意图、当前合同、执行、决策和最终代码。

布局与组件

主区合同/执行记录/交付物/决策 Tab；右区状态、依赖、工作区与流程版本；主按钮依当前状态变化。

字段与信息层级

taskId、revision、approval 状态、workflowVersion、activeRun、snapshot、unresolvedIssues、merge 状态。

操作与流转

开始、请求暂停、补充需求、创建新 revision、重新执行；编辑活跃任务先暂停并生成新版本，不改旧执行历史。

异常与限制

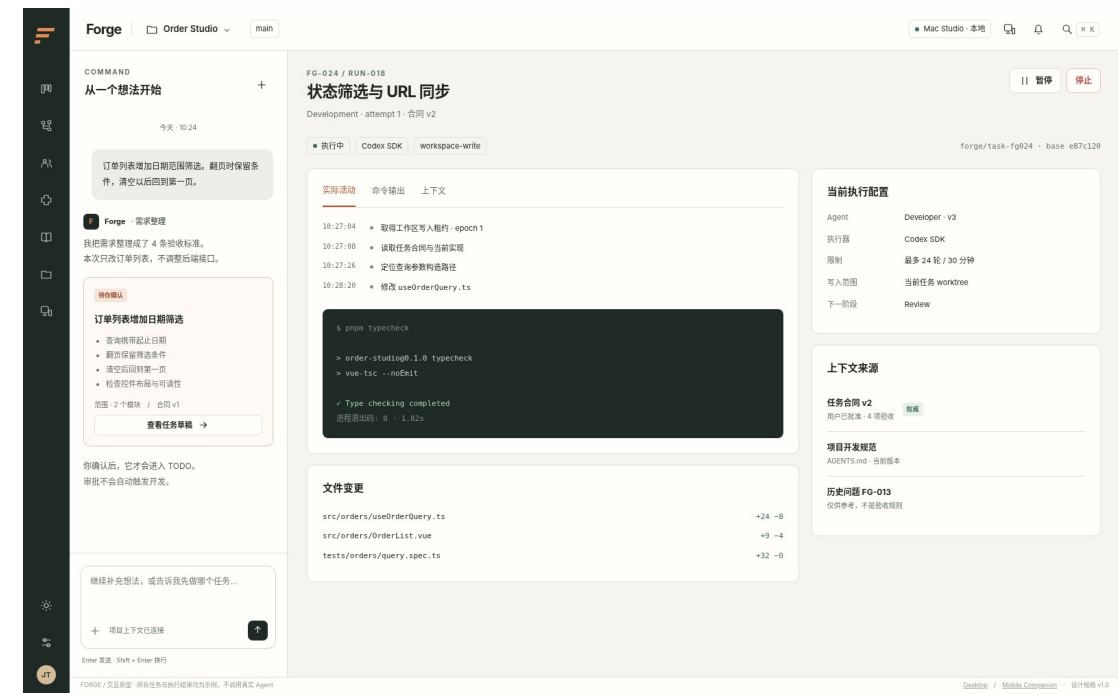
前置依赖未完成→Blocked；运行仍在停止→禁止再次开始；已归档→只读；旧报告带“针对旧快照”。

接口与命令

tasks/{id}、runs 查询、runs.start/tasks.revise/runs.pause/runs.cancel。

D04 · 执行观察与控制

页面 D04 · 路由 #run · 阶段 P2 / P3 · 模块 M07,M09,M13



执行观察与控制 · 交互原型示意

页面目的

只展示真实动作、产物与可核查摘要；提供可靠的停止、恢复和排障入口。

布局与组件

主区时间线与终端/差异/产物 Tab；右区冻结配置、预算、上下文来源；顶部状态、暂停、停止。

字段与信息层级

runId、attemptId、stepId、lastSeq、executor/sessionRef、usage.actualOrEstimated、lease、processStatus。

操作与流转

暂停→pausing 直到执行器确认；停止→canceling 直到进程树退出；点击事件定位产物；导出脱敏运行包。

异常与限制

事件断线→保留最后 seq 并补拉；未知外部副作用→reconcile_required；日志过长虚拟滚动；隐藏敏感值。

接口与命令

runs/{id}、runs/{id}/events、runs.pause/resume/cancel；artifacts 只读。

D05 · Review 与代码证据

页面 D05 · 路由 #review · 阶段 P3 · 模块 M10,M11

页面目的

让审查判断绑定需求版本和代码快照，而不是绑定开发者的完成声明。

布局与组件

左主区 Diff + 文件列表；问题卡可定位代码；右区快照、阻塞项、风险接受与审查来源。

字段与信息层级

reviewIssue{id,severity,blocking,file,line,evidence,status}；taskRevision；snapshotId；reviewerProfileVersion。

操作与流转

退回开发携带问题；采纳修复后在新快照复审；用户显式接受风险，不能伪造 reviewPassed。

异常与限制

快照变更→stale；结果缺证据→incomplete；仍有阻塞项→禁止普通通过；敏感文件内容遮挡。

接口与命令

Review 结果与 issue 状态更新/review.acceptRisk；step result schema；artifact.diff 查询。

D06 · 验证与人工交付验收

页面 D06 · 路由 #verify · 阶段 P3 / P6 · 模块 M12

页面目的

逐条验收并区分构建通过、需求通过与最终交付接受。

布局与组件

顶部构建/类型检查/测试/快照指标；主区每条 AC 与证据；右区交付摘要；底部人工接受与退回。

字段与信息层级

AC 状态 passed/failed/not_run/needs_human/not_applicable（需理由）；snapshotId、reportRef、unresolvedIssues、humanDecision。

操作与流转

运行预设命令；查看日志；人工完成未自动化项；接受精确快照后进入 Done；合并是独立授权动作。

异常与限制

无测试框架→not_run 而非 passed；命令退出 0 但测试 0 条→按配置标记不充分；结果过期需重新运行。

接口与命令

verify.run/acceptance.decide/拒绝验收/Review 结果触发返工/deliveries.merge；verified snapshot CAS。

D07 · workflows模板库

页面 D07 · 路由 #workflows · 阶段 P5 · 模块 M06

页面目的

默认可用，但不限制用户只能使用固定研发流程。

布局与组件

模板卡 Standard/Fast/Strict；每张显示节点摘要、版本、引用任务数；项目默认设置独立。

字段与信息层级

workflowId/version/name/nodeCount/reworkLimit/finalAcceptance；draft/published/retired。

操作与流转

复制模板；编辑草稿；设项目默认；导入受限 JSON/YAML；只归档无新任务使用，不破坏旧 Run。

异常与限制

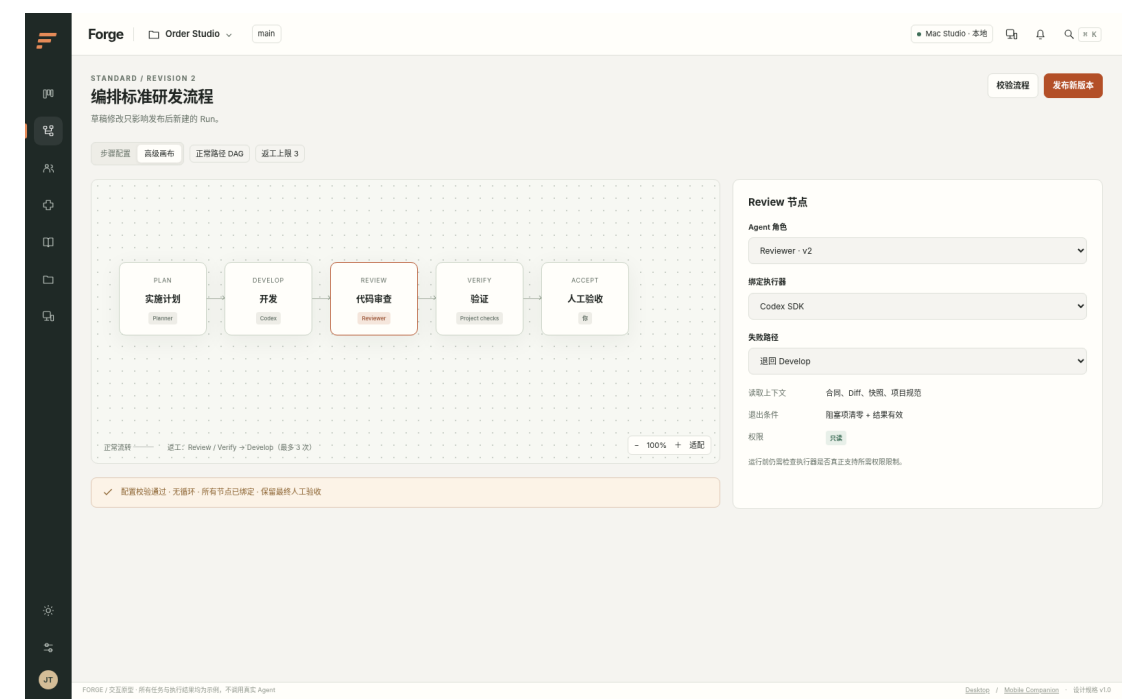
缺少插件→禁用开始并定位节点；非法配置显示语义错误；升级只影响新 Run。

接口与命令

workflow.list/get/workflows.saveDraft/publish/setProjectDefault。

D08 · 工作流编排器

页面 D08 · 路由 #workflow · 阶段 P5 · 模块 M06,M08



工作流编排器 · 交互原型示意

页面目的

以同一份声明式定义支撑表单编排与高级画布，不维护两套引擎。

布局与组件

工具栏步骤配置/高级画布；中区节点；右区选中节点表单；底部校验结果。实线正常路径，虚线有界返工。

字段与信息层级

节点 type/profile/verifier/context/permissions/entryGate/exitGate；正常 edges；reworkRoutes；maxAttempts；boardColumn。

操作与流转

增删节点、排序、连线、绑定角色、配置失败出口；发布前编译验证；快照化生成新 workflowVersion。

异常与限制

正常图环路/悬空节点/无出口/不兼容权限→不能发布；删除被引用角色提示具体节点；并行写入后置。

接口与命令

workflows.validate/workflows.publish；WorkflowSchema + semantic compiler。

D09 · Agent 角色库

页面 D09 · 路由 #agents · 阶段 P4 · 模块 M09

页面目的

把角色、执行器、模型和权限分开配置，而不是给一个模型取几个名字。

布局与组件

角色卡：目标、执行器、模型来源、权限概要、状态、版本；筛选开发/审查/产品；兼容性横幅。

字段与信息层级

profileId/revision/executorId/provider/modelRef/contextSources/requiredCapabilities/budget/outputSchema。

操作与流转

创建/复制/编辑；能力探测；创建新版本；只展示当前执行器支持的模型；只读要求无法落实时阻断。

异常与限制

凭据未配置、执行器未安装、模型不支持均有明确修复路径；配置开关不得假装权限已生效。

接口与命令

agents.list/executors.probe/profiles.save。

D10 · 角色与执行器配置

页面 D10 · 路由 #profile · 阶段 P4 · 模块 M09,M17

页面目的

使角色配置可审阅、可版本化，并显式说明底层执行限制。

布局与组件

左表单角色指令、执行器、模型、上下文；右权限/预算/能力报告；下部输出 Schema 与测试连接。

字段与信息层级

角色名、说明、系统指令模板、executorId、modelRef、toolAllowlist、maxCalls/maxCost、credentialRef，不展示原始 Key。

操作与流转

探测能力；使用已授权凭据；测试安全任务；保存新 revision；导出配置时剔除凭据。

异常与限制

危险权限扩大→本机确认；不支持 native pause→标记阶段边界暂停；云模型数据发送范围提示。

接口与命令

profiles.save/executors.probe/credentials.set (local only) 。

D11 · 插件管理

页面 D11 · 路由 #plugins · 阶段 P4 · 模块 M08,M16

页面目的

展示贡献点、权限和生命周期；首版只启用随应用发布的可信内置插件。

布局与组件

插件卡分 Executor/Context/Verifier/Tools；详情有版本、API 范围、依赖、权限和活跃引用。

字段与信息层级

manifest、source、checksum、compatibility、state、activeRunRefs、requested/granted permissions。

操作与流转

启用；试探依赖；禁用进入 draining；查看失败日志；只读查看注册；任意网络下载安装不在 v1。

异常与限制

版本不兼容→quarantined；缺依赖→blocked；活跃 Run 不热卸载；删除监听不撤销既有外部副作用。

接口与命令

plugins.list/enable/disable；public PluginApi。

D12 · 项目知识与记忆

页面 D12 · 路由 #knowledge · 阶段 P5 · 模块 M14,M15

页面目的

明确 Agent 参考了什么、哪些事实已确认、哪些只是候选经验。

布局与组件

资料/项目记忆/上下文记录 Tab；来源列表；规则预览；右侧记忆候选审核与失效说明。

字段与信息层级

sourceId/version/hash/projectScope/status；chunk 原文定位；memory candidate/validated/expired/revoked；contextBundle。

操作与流转

导入 MD/TXT/OpenAPI；检索试验；确认候选；过期/撤销；从任务查看本轮引用；删除触发索引与缓存清理。

异常与限制

跨项目结果禁止；来源冲突展示两边而非自行择真；无检索结果标缺信息；删除来源不抹除必要审计但正文按保留策略处理。

接口与命令

knowledge.import/revoke/retrieve；memories.propose/validate/revoke；contexts/{id}。

D13 · 项目与环境设置

页面 D13 · 路由 #projects · 阶段 P1 / P6 · 模块 M02,M10

页面目的

以显式授权的仓库与命令建立可运行环境，不让聊天指定任意宿主路径。

布局与组件

项目列表/名称/仓库路径/基准分支；检查命令表；右侧 Git、Node、SDK、工作区能力检测。

字段与信息层级

canonicalRepoPath、baseBranch、environmentId、commandPresets[exe,args,cwd,timeout]、allowedPaths、sensitivePaths。

操作与流转

系统文件夹选择；探测环境；保存命令批准记录；运行安全检查；更换项目撤销旧路径上下文。

异常与限制

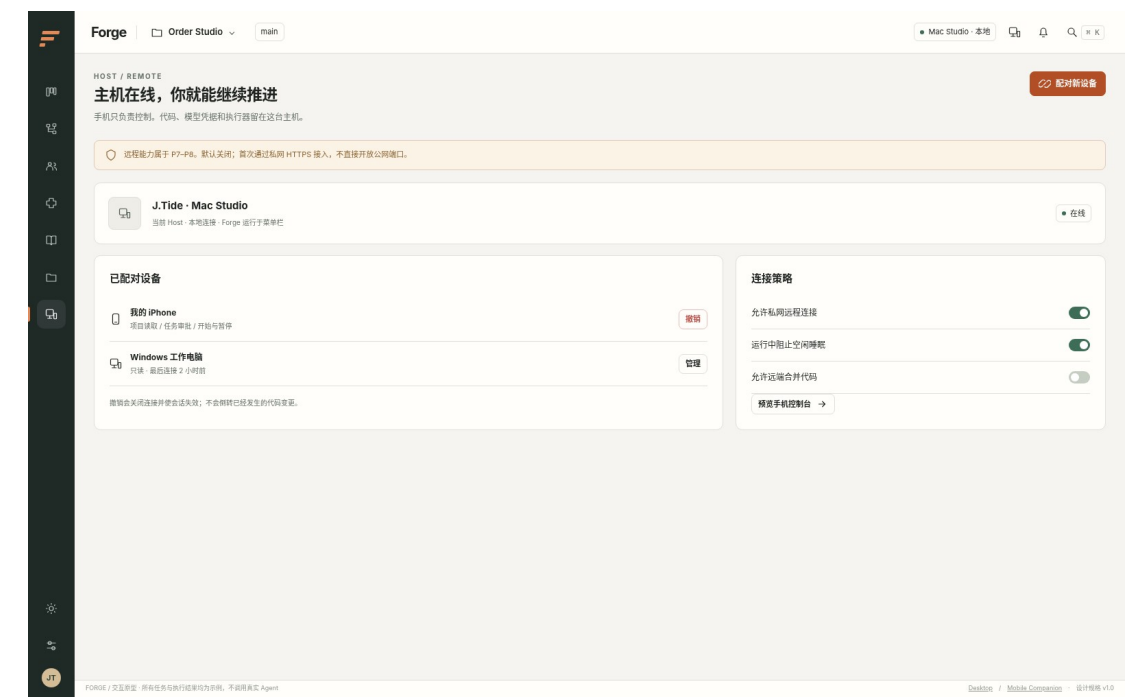
脏主工作区不 stash 或覆盖；不存在分支提示；脚本变化批准失效；符号链接越界拒绝。

接口与命令

projects.create/update、environments.probe、commandPresets.approve。

D14 · 远程连接与设备

页面 D14 · 路由 #devices · 阶段 P7 · 模块 M20



远程连接与设备 · 交互原型示意

页面目的

将同一 Host 安全暴露给用户自己的手机；默认不开远程服务。

布局与组件

本地主机卡在线状态；远程开关与网关检查；配对面板；已连接设备、scope、最后访问、撤销。

字段与信息层级

hostId/origin/deviceId/pairExpiresAt/scopes/sessionVersion/lastSeen；不展示可复制长期 Token。

操作与流转

明确启用私有 HTTPS；生成一次性配对码；本机批准设备；配置 project allowlist；撤销即时失效并断开事件流。

异常与限制

主机睡眠/退出→离线；证书/Origin 不匹配不绕过；二维码超时重新生成；来源公网默认拒绝。

接口与命令

devices.pair.issue/devices.pair.decide；/pair/claim/status；devices.revoke；gateway configuration local only。

D15 · 应用设置、诊断与更新

页面 D15 · 路由 #settings · 阶段 P6 · 模块 M01,M17,M23

页面目的

建立日常可使用、可恢复和可安全升级的桌面体验。

布局与组件

外观/快捷键/凭据/数据/更新/关于子导航；数据与工作区删除分开；诊断导出预览。

字段与信息层级

theme、density、closeBehavior、retention、updateChannel、installedVersion、migrationState。

操作与流转

切换主题；配置保留；凭据仅 set/replace 不回显；检查签名更新；活跃 Run 延迟安装；导出脱敏诊断。

异常与限制

数据库迁移失败只读恢复；更新失败继续旧版；密钥加密不可用明确拒绝保存；不自动上传遥测。

接口与命令

settings.update、diagnostics.prepare、updates.check、credentials.set/clear (local only) 。

19 · 手机 Companion 设计

手机不是缩小的 Desktop 看板，也不是在 iPhone 或 Android 运行 Electron。先交付响应式 Vue PWA，通过 RemoteTransport 连接同一个在线 Host。后续只有需要推送、原生安全存储或分发时再加 Capacitor 外壳。[S06]

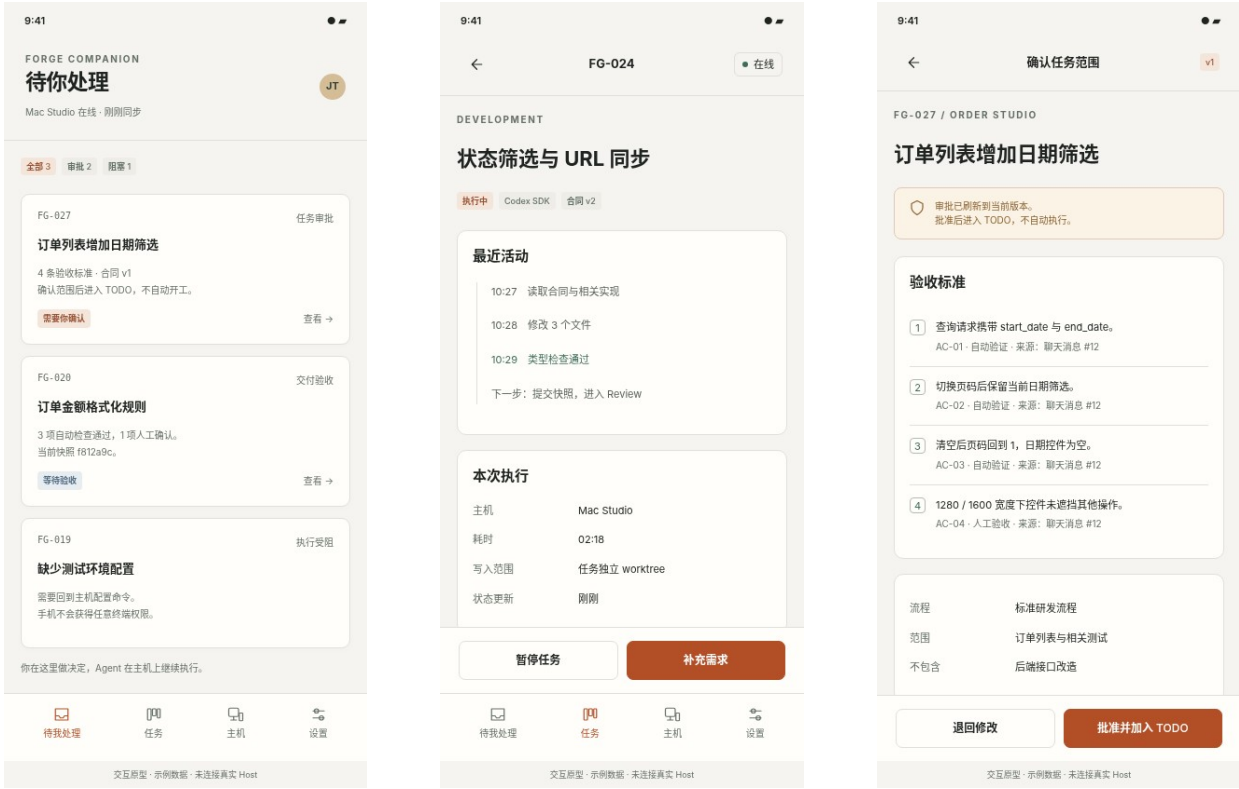


图 9 · 手机收件箱、运行进度、版本化审批。所有内容为原型示例。

小屏优先顺序：待我处理→任务摘要→审批与澄清。默认不编辑流程/权限，不安装插件，不操作任意终端。后台时 SSE 可能断开，回前台重新取快照并接续游标；审批先刷新版本。

MOB01 · 手机待办与审批收件箱

MOB01 · P8

目的

优先显示需要人处理的事情，而不是缩小的五列看板。

布局

主机在线条；审批/阻塞任务卡；底部待办/任务/主机；大于 44px 点击目标。

字段

hostId、lastSync、pendingApprovalCount、taskTitle、kind、expiresAt、revision、projectName。

操作

进入审批、查看运行、补充需求草稿；在线可提交受限命令；手机不改角色权限与命令白名单。

离线与安全

离线只显示最后脱敏快照；不缓存代码/密钥；不离线排队任何审批或执行。

接口

RemoteTransport GET inbox/tasks + SSE；server authoritative state。

MOB02 · 手机任务与实时进度

MOB02 · P8

目的

离开电脑时了解执行并处理合理的暂停/澄清，不提供任意远程 Shell。

布局

单任务标题、阶段、最近动作、关键产物摘要；底部暂停/补充；高风险 Diff 指向 Desktop 查看。

字段

run/attempt/step 状态、lastSeq、Host 在线、snapshot、budget、pendingAction。

操作

请求暂停或取消（按 scope）；补充需求创建草稿；页面关闭不停止 Host。

离线与安全

断线保留 seq；事件 gap 重拉快照；请求已送但回执丢失按 idem 查询，不盲目重复；后台不能保证持续 SSE。

接口

runs.query/events；runs.pause/cancel；conversations.send；command receipts。

MOB03 · 手机版本化审批

MOB03 · P8

目的

确认明确的任务版本或交付快照；在小屏上保留必要的风险与范围信息。

布局

审批种类/版本/来源；可折叠 AC/范围/风险；底部拒绝与批准固定显示。

字段

approvalId/kind/taskRevision/snapshotId/expiresAt/scopes/decision。

操作

进入页先刷新；确认当前版本；CSRF + idempotency 提交；显示 receipt；权限扩大/密钥/安装插件必须回本机。

离线与安全

版本变化 409→展示差异后重审；撤销设备→401 锁定；过期按钮失效；连续点击只能一次 effect。

接口

approvals.get/approvals.decide + expectedRevision；HttpOnly session；Origin/CSRF。

20 · 实施路线、依赖与里程碑

所有任务初始状态 not_started。按依赖推进，每阶段都有能运行的产物。阶段完成不是“目录都建好了”，而是对应路径真实跑通且有验收证据。任务计划中的测试引用按模块覆盖，实施时将每个 T 编号映射到具体测试文件。

阶段	目标与出口	任务数
P0 工程基线与可行性闸门	可启动的双平台桌面骨架；通过 SDK、SQLite ABI、取消进程树等技术风险验证。	8
P1 自然语言入口与审批看板	从想法生成草稿，经人类审批进入 TODO，尚不自动写代码。	10
P2 单执行器真实开发闭环	一张已批准任务在独立工作区真实修改，并可查看结果和停止。	10
P3 审查、验证、返工与恢复	以任务版本和快照为依据形成可验收交付，不把绿灯当证据。	12
P4 插件体系与第二执行器	用真实第二实现证明能力可替换，而不是只抽空接口。	10
P5 流程定制、知识与项目记忆	默认模板与高级编辑共用同一执行定义，补齐上下文与经验边界。	12
P6 跨端 Desktop v1.0 产品化	以完整可用而非功能演示为目标，交付两个平台安装包。	10
P7 远程宿主与安全网关	保持核心不变，给在线 Windows/Mac 主机增加受控远程入口。	10
P8 手机 PWA Companion	在小屏完成查看、澄清、审批、开始/暂停和取消，执行仍在 Host。	10
P9 可选增强与持续扩展	只在 Desktop 和远程稳定后做，不阻塞 v1.0/v1.1。	8

P3 结束形成首个可用闭环；P0-P6 为 Desktop v1.0 完整范围。P7-P8 为远程与手机 v1.1，P9 可选。所有阶段都不纳入独立测试产品的代码或实现范围。

工期仅作容量规划：单人全栈+AI 辅助，P0-P6 约 60-100 个工程日；远程/手机另约 20-35 个工程日。未做原型压测或估时标定，实际范围以 P0 风险实验与真实速度调整。并行分工可缩短日历时间，但不跳过依赖和实机验收。

前十个工程日建议先完成 P0 风险：工程与安全壳→Host/数据库→真实 SDK 探测→工作区路径与取消→首个命令闭环。若某 SDK 无法实现所需权限，记录 ADR 并改用支持的受控路径，不进入大量 UI 开发后才处理。

P0 · 工程基线与可行性闸门

可启动的双平台桌面骨架；通过 SDK、SQLite ABI、取消进程树等技术风险验证。

P0-01 · 仓库、工作区与版本锁定

模块 M01；依赖 无；对应测试 T001, T002, T003, T004, T005

落地位置：apps/* / packages/contracts / pnpm-workspace.yaml

实现：建立 pnpm 工作区、TS 严格模式、lint/typecheck/test 脚本；填写版本与许可证矩阵，不使用浮动 latest。

验收：全新目录可按 README 安装；lockfile 受 CI 约束；版本均有探测证据。

P0-02 · 桌面壳与共享 Web 入口

模块 M01；依赖 P0-01；对应测试 T001, T002, T003, T004, T005

落地位置：apps/desktop / apps/web / packages/client

实现：实现 Electron 安全壳和 Vue 入口；客户端通过 LocalTransport 连接 Host，不在 renderer 导入 Node。

验收：Windows/Mac 启动显示 Host 健康；恶意 IPC 被拒绝。

P0-03 · Host 与 CommandBus 最小实现

模块 M19；依赖 P0-02；对应测试 T091, T092, T093, T094, T095

落地位置：apps/host / packages/core/commands

实现：实现 typed command、query、event 与身份注入；先用 ping 和项目读取证明无 UI 可运行。

验收：同一命令处理器可从 CLI 测试与 Desktop 调用，无重复业务代码。

P0-04 · 数据库与原生模块风险测试

模块 M18；依赖 P0-03；对应测试 T086, T087, T088, T089, T090

落地位置：packages/storage / tests/storage

实现：执行 DDL，启用 FK/WAL；分别构建 Electron 与 Node 需要的 ABI；备份恢复一份 fixture。

验收：Mac/Windows 读写迁移通过；若 ABI 失败先解决，不继续接业务。

P0-05 · Codex SDK 兼容探测

模块 M09；依赖 P0-04；对应测试 T041, T042, T043, T044, T045

落地位置：plugins/executor-codex / docs/compatibility

实现：按官方版本验证只读、结构化输出、取消、session、auth；不可用能力写 false。

验收：真实只读任务完成；有版本和 usage 日志；不编造暂停/审批能力。

P0-06 · 跨平台工作区与进程取消探测

模块 M10；依赖 P0-05；对应测试 T046, T047, T048, T049, T050

落地位置：packages/workspace / packages/process

实现：在中文/空格路径创建 worktree，启动带子进程的 fixture 并取消，核对 tree 与退出。

验收：两平台无残留写进程；失败目录隔离而非释放租约。

P0-07 · 设计 Token 与基础组件

模块 M22；依赖 P0-06；对应测试 T106, T107, T108, T109, T110

落地位置：packages/ui / apps/web/layouts

实现：落实配色/字号/间距/焦点；建立 button/dialog/card/status/empty/error 组件。

验收：1280/1600 宽与 125%DPI 可读，键盘操作对话框不丢焦点。

P0-08 · 契约自动校验与 CI 入口

模块 M24；依赖 P0-07；对应测试 T116, T117, T118, T119, T120

落地位置：contracts / scripts / .github/workflows

实现：导入 Schema/示例/SQL/ workflows semantic validator；跑 unit 矩阵并记录未验证 SDK 项。

验收：CI 任何契约冲突失败；Mock 与真实 smoke 清楚分开。

P1 · 自然语言入口与审批看板

从想法生成草稿，经人类审批进入 TODO，尚不自动写代码。

P1-01 · 项目选择与可信环境向导

模块 M02；依赖 P0-08；对应测试 T006, T007, T008, T009, T010

落地位置：apps/web/pages/projects / core/projects

实现：文件选择→Git 读取→Trust→检查命令确认，保存绝对规范路径与环境 ID。

验收：脏目录不被修改，无 Git 时不自动初始化。

P1-02 · 项目及环境数据服务

模块 M02；依赖 P1-01；对应测试 T006, T007, T008, T009, T010

落地位置：storage/projects / core/environments

实现：实现项目 CRUD、环境/命令预设版本与归属检查；归档非删除运行记录。

验收：不同项目不可访问彼此环境，所有写操作 CAS。

P1-03 · 会话与消息流

模块 M03；依赖 P1-02；对应测试 T011, T012, T013, T014, T015

落地位置：core/conversations / web/chat

实现：持久化消息、流式输出、失败重试；保留草稿输入，Markdown 净化。

验收：重复请求不产生重复消息；失败保留用户原文。

P1-04 · 整理器与结构化任务生成

模块 M03；依赖 P1-03；对应测试 T011, T012, T013, T014, T015

落地位置：plugins/refiner / core/drafts

实现：实现意图分类、受限读项目、TaskContract 输出与最多两次 Schema 修复。

验收：典型 feature/bug 能生成草稿；模糊事项保留问题，无写代码工具。

P1-05 · 草稿编辑与澄清

模块 M04；依赖 P1-04；对应测试 T016, T017, T018, T019, T020

落地位置：web/draft-sheet / core/task-revisions

实现：每次确认修改产生 revision；显示差异、验收稳定 ID、scope 提议与来源。

验收：关闭重开不丢草稿；未回答阻塞问题不能批准。

P1-06 · 审批与原子入 TODO

模块 M04；依赖 P1-05；对应测试 T016, T017, T018, T019, T020

落地位置：core/approvals / storage/transactions

实现：canonical hash+CAS+idempotency；人类审批与 task 状态/event 同事务。

验收：双击/两客户端只批准一次，旧 revision 返回 409。

P1-07 · 任务看板与同列排序

模块 M05；依赖 P1-06；对应测试 T021, T022, T023, T024, T025

落地位置：web/board / core/task-projection

实现：五列投影、筛选、手工创建、同列移动；使用虚拟列表策略。

验收：列不会被随意 PATCH；无任务时引导创建而非营销空屏。

P1-08 · 任务详情与来源链

模块 M05；依赖 P1-07；对应测试 T021, T022, T023, T024, T025

落地位置：web/task-detail / core/queries

实现：展示目标/AC/约束/依赖/来源消息，链接稳定 taskId。

验收：任一验收项可找到来源或人工决定。

P1-09 · 自然语言控制提议

模块 M03；依赖 P1-08；对应测试 T011, T012, T013, T014, T015

落地位置：core/intent-commands / web/chat

实现：支持降优先级/暂停提议/修订草稿；危险动作生成确认而非直接执行。

验收：“忽略审批马上合并”不能绕过命令授权。

P1-10 · P1 集成与手工降级

模块 M24；依赖 P1-09；对应测试 T116, T117, T118, T119, T120

落地位置：tests/p1 / docs/demo

实现：断网手工建任务，完整从消息到审批入列；录制可重复 fixture。

验收：没有模型 key 时仍可使用任务与看板；验收 T011-T025 通过。

P2 · 单执行器真实开发闭环

一张已批准任务在独立工作区真实修改，并可查看结果和停止。

P2-01 · 不可变 RunConfig

模块 M07；依赖 P1-10；对应测试 T031, T032, T033, T034, T035

落地位置：core/runs / storage/run-config

实现：冻结 contract/workflow/profile/plugin 版本、预算与环境，不读取运行中动态设置。

验收：修改全局设置不影响已启动 Run。

P2-02 · 工作区租约与基线快照

模块 M10；依赖 P2-01；对应测试 T046, T047, T048, T049, T050

落地位置：workspace/leases / workspace/git

实现：任务分支、worktree、排除路径、single writer 和 epoch；保存初始 base。

验收：重复 Start 不分配第二写入者，原主目录保持不变。

P2-03 · ExecutorAdapter 公共接口

模块 M09；依赖 P2-02；对应测试 T041, T042, T043, T044, T045

落地位置：plugin-api / contracts/events

实现：落实 start/probe/cancel/optional resume 以及标准事件；任何 upstream 输出先校验。

验收：单元测试覆盖乱序/重复/非法输出。

P2-04 · Codex 真实写入适配

模块 M09；依赖 P2-03；对应测试 T041, T042, T043, T044, T045

落地位置：plugins/executor-codex

实现：使用 P0 验证的 SDK 组合；工作范围与账号明确；收集结果和 native sessionRef。

验收：在演示仓库完成一项真实功能，无假事件。

P2-05 · 运行调度与 Attempt

模块 M07；依赖 P2-04；对应测试 T031, T032, T033, T034, T035

落地位置：core/scheduler / core/attempts

实现：实现 queued→running→terminal，启动 intent 先落盘；timeout 和事件 epoch 检查。

验收：旧 Attempt 回包不会污染新 Run。

P2-06 · 工作记忆与 ContextBundle

模块 M15；依赖 P2-05；对应测试 T071, T072, T073, T074, T075

落地位置：core/context / storage/checkpoints

实现：保存当前目标/已做动作/问题/预算；为执行器构建带来源的输入包。

验收：不用完整历史无限拼接；恢复能解释进度但不假定进程还在。

P2-07 · Diff 与初版运行详情

模块 M13；依赖 P2-06；对应测试 T061, T062, T063, T064, T065

落地位置：web/run / web/diff / artifacts

实现：流式日志限流、文件树、文本 diff、usage 未知态和上下文来源。

验收：终端输出不能执行 HTML/脚本，UI 状态来自真实事件。

P2-08 · 取消、停止与超时

模块 M07；依赖 P2-07；对应测试 T031, T032, T033, T034, T035

落地位置：process/manager / core/cancel

实现：先暂停调度再取消进程树，无法确认退出时隔离 workspace。

验收：取消后没有继续写文件；未知状态不宣称成功。

P2-09 · 开发结果与交接快照

模块 M10；依赖 P2-08；对应测试 T046, T047, T048, T049, T050

落地位置：workspace/snapshot / core/handoff

实现：将允许的变更固化 snapshot，保存摘要/未完成项/artifact 引用。

验收：新增文件被捕获，secret 扫描阻断敏感文件进入产物。

P2-10 · P2 纵向真实 Demo

模块 M24；依赖 P2-09；对应测试 T116, T117, T118, T119, T120

落地位置：tests/p2 / fixtures/orders

实现：输入任务→批准→启动→真实修改→Diff→停止/完成；保存人工检查结果。

验收：至少一次真实模型成功和一次失败可完整追溯。

P3 · 审查、验证、返工与恢复

以任务版本和快照为依据形成可验收交付，不把绿灯当证据。

P3-01 · 审查副本与权限

模块 M10；依赖 P2-10；对应测试 T046, T047, T048, T049, T050

落地位置：workspace/review-copy / policy

实现：在固定 snapshot 创建审查副本；验证真实只读能力，不支持则明确阻断。

验收：Reviewer 不能静默改变被审实现。

P3-02 · Review Profile 与结果 Schema

模块 M11；依赖 P3-01；对应测试 T051, T052, T053, T054, T055

落地位置：presets/agents / core/review

实现：独立上下文、阻塞/建议、文件 anchor、来源 AC 及不确定项。

验收：无结果/非法结果不能 approved。

P3-03 · 问题列表与退回交接

模块 M11；依赖 P3-02；对应测试 T051, T052, T053, T054, T055

落地位置：web/review / core/issues

实现：Issue 关联 snapshot 和 attempt，生成 new develop handoff，不复制全部聊天。

验收：同问题可追溯每次修复，不重复膨胀卡片。

P3-04 · 命令验证器

模块 M12；依赖 P3-03；对应测试 T056, T057, T058, T059, T060

落地位置：plugins/verifier-project

实现：按批准 argv/cwd/env 执行 build/typecheck/test；解析 exit 与报告并保存证据。

验收：stdout 含 PASS 但 exit!=0 仍失败；无测试为 not_configured。

P3-05 · 验收矩阵

模块 M12；依赖 P3-04；对应测试 T056, T057, T058, T059, T060

落地位置：web/verify / core/acceptance

实现：每条 required AC 对应自动/人工状态，支持人工风险接受与未验证说明。

验收：未覆盖必需项不能静默完成。

P3-06 · 有限返工循环

模块 M07；依赖 P3-05；对应测试 T031, T032, T033, T034, T035

落地位置：core/rework

实现：Review/Verify 失败新 Attempt，共享全局重做计数；新快照失效旧后继。

验收：无限循环被阻止，达到阈值转 blocked。

P3-07 · 人类最终验收

模块 M04；依赖 P3-06；对应测试 T016, T017, T018, T019, T020

落地位置：core/approval-accept / web/accept

实现：审批绑定当前 contract+snapshot+reports；要求 fresh 读取。

验收：旧快照上的确认被拒绝。

P3-08 · 交付记录与显式合并

模块 M12；依赖 P3-07；对应测试 T056, T057, T058, T059, T060

落地位置：core/delivery / core/merge

实现：Done 与 merged 分开；合并先 operation intent 并绑定 targetHead；冲突不 force。

验收：重复命令不重复合并，目标变化要求重验。

P3-09 · 崩溃恢复与 reconcile

模块 M07；依赖 P3-08；对应测试 T031, T032, T033, T034, T035

落地位置：core/recovery / host/startup

实现：核对 PID/startTime/session/lease，原生能力允许才 resume，否则 interrupted。

验收：在副作用前后注入崩溃均不会盲目重跑。

P3-10 · 配置/需求变化失效链

模块 M04；依赖 P3-09；对应测试 T016, T017, T018, T019, T020

落地位置：core/revisions / core/invalidation

实现：新 revision 保留旧 run；pendingChange 按安全点处理；报告变 stale。

验收：开发中更改目标不偷偷污染当前上下文。

P3-11 · 备份与磁盘故障处理

模块 M18；依赖 P3-10；对应测试 T086, T087, T088, T089, T090

落地位置：storage/backup / artifacts/store

实现：一致性备份、迁移前检查、空间不足只读诊断。

验收：故障后已批准任务可恢复，WAL 未遗漏。

P3-12 · P3 可交付验收样例

模块 M24；依赖 P3-11；对应测试 T116, T117, T118, T119, T120

落地位置：tests/p3 / docs/demo

实现：正常路径、Review 退回、测试失败、人工豁免、崩溃恢复各跑一次。

验收：一张 TODO 到 Done 可追溯全链，必需测试通过。

P4 · 插件体系与第二执行器

用真实第二实现证明能力可替换，而不是只抽空接口。

P4-01 · Manifest 和版本解析

模块 M08；依赖 P3-12；对应测试 T036, T037, T038, T039, T040

落地位置：plugin-host/manifest

实现：加载前 Schema、apiRange、平台、配置和 source 检查，不执行未授权 entry。

验收：错误清单无代码副作用。

P4-02 · Registry 与 DisposableScope

模块 M08；依赖 P4-01；对应测试 T036, T037, T038, T039, T040

落地位置：plugin-host/registry

实现：服务注册、重复名检查、依赖拓扑、资源逆序清理。

验收：半激活失败不泄露监听器/服务。

P4-03 · 内置插件装配与锁

模块 M08；依赖 P4-02；对应测试 T036, T037, T038, T039, T040

落地位置：host/bootstrap / plugins.lock

实现：内置列表精确版本/摘要，Run 绑定插件版本；draining 停用。

验收：运行中更新不会换掉 adapter。

P4-04 · 配置生成表单

模块 M22；依赖 P4-03；对应测试 T106, T107, T108, T109, T110

落地位置：web/plugins / ui/schema-form

实现：从 configSchema 生成表单、secret 字段凭据引用、兼容提示。

验收：未知字段不提交，密钥不回显。

P4-05 · Claude SDK 真实适配

模块 M09；依赖 P4-04；对应测试 T041, T042, T043, T044, T045

落地位置：plugins/executor-claude

实现：使用官方 API-key 方式集成，运行同一 Executor 合约测试，不偷用订阅登录。

验收：与 Codex 切换不用改 Core；至少一真实任务可交付。

P4-06 · Agent Profile 与能力选择

模块 M09；依赖 P4-05；对应测试 T041, T042, T043, T044, T045

落地位置：core/profiles / web/agents

实现：模型/执行器/角色分离；灰掉不兼容组合；角色 prompt 和权限版本化。

验收：只读/网络/审批要求无法满足则无法启动。

P4-07 · ModelProvider 与整理器替换

模块 M03；依赖 P4-06；对应测试 T011, T012, T013, T014, T015

落地位置：plugins/model-provider / refiner

实现：抽流式文本/结构化输出/usage、明确每个 provider 认证；capability 检测。

验收：关闭一 provider 不破坏看板，手工 Draft 仍可用。

P4-08 · 工具/MCP 入口契约

模块 M16；依赖 P4-07；对应测试 T076, T077, T078, T079, T080

落地位置：plugin-api/tools / plugin-host/tools

实现：实现受控 ToolRegistry 和 mock MCP 契约测试；v1 默认不开任意外部 MCP。

验收：工具注册不授予权限，注入指令不能触发审批。

P4-09 · 插件故障隔离与诊断

模块 M08；依赖 P4-08；对应测试 T036, T037, T038, T039, T040

落地位置：host/plugin-supervisor / web/diagnostics

实现：捕获激活/运行/卸载错误，显示具体 pluginId 与 Run 影响。

验收：插件失败 UI 保持可用，核心事件可读。

P4-10 · P4 替换性验收

模块 M24；依赖 P4-09；对应测试 T116, T117, T118, T119, T120

落地位置：tests/plugins / docs/plugin-authoring

实现：同 TODO 分别跑两个真实执行器、卸载上下文、替换验证器 fixture。

验收：不修改 Core 达到替换，形成插件开发说明。

P5 · 流程定制、知识与项目记忆

默认模板与高级编辑共用同一执行定义，补齐上下文与经验边界。

P5-01 · 标准/快速/严格模板

模块 M06；依赖 P4-10；对应测试 T026, T027, T028, T029, T030

落地位置：presets/workflows

实现：标准全流程，快速可省 Plan 但保留验收，严格增加人类门禁；Schema 统一。

验收：所有模板能编译且终点有验收。

P5-02 · Workflow 编译器

模块 M06；依赖 P5-01；对应测试 T026, T027, T028, T029, T030

落地位置：core/workflow/compiler

实现：DAG 可达/唯一/绑定/输出/能力/预算/返工规则静态校验，条件 DSL 无 eval。

验收：非法环和缺插件在启动前阻止。

P5-03 · 线性配置编辑体验

模块 M06；依赖 P5-02；对应测试 T026, T027, T028, T029, T030

落地位置：web/workflows

实现：增删/排序节点、绑定 agent/verifier、失败路径、保存草稿与发布。

验收：非工程用户无需画图可改流程。

P5-04 · 高级画布编辑

模块 M06；依赖 P5-03；对应测试 T026, T027, T028, T029, T030

落地位置：web/workflow-builder

实现：Vue Flow 显示同一 DSL，布局数据与语义分离；v1 并行写禁止。

验收：画布导入导出往返不丢语义，错误高亮到节点。

P5-05 · 工作流版本冻结

模块 M07；依赖 P5-04；对应测试 T031, T032, T033, T034, T035

落地位置：core/workflow/versioning

实现：草稿与 published 不可变，RunConfig 保留 hash；影响范围预览。

验收：旧 Run 继续旧流程，新 Run 用新版本。

P5-06 · 知识导入与原文定位

模块 M14；依赖 P5-05；对应测试 T066, T067, T068, T069, T070

落地位置：context/ingestion / web/knowledge

实现：先支持 Markdown/TXT/OpenAPI 文本；白名单目录/大小；结构切分和 hash。

验收：引用能回到原文范围，导入失败可重试。

P5-07 · FTS 与中文检索

模块 M14；依赖 P5-06；对应测试 T066, T067, T068, T069, T070

落地位置：context/retrieval / tests/rag

实现：project/env/version 过滤后关键词搜索，中文分词/字符索引回归集。

验收：跨项目 0 返回；代码 symbol 可找；无答案不编造。

P5-08 · Context Builder 预算与冲突

模块 M14；依赖 P5-07；对应测试 T066, T067, T068, T069, T070

落地位置：core/context-builder

实现：按权威顺序组装、截断标记、source 清单、冲突追问。

验收：不足时明确显示，不以过期记忆覆盖合同。

P5-09 · 项目记忆生命周期

模块 M15；依赖 P5-08；对应测试 T071, T072, T073, T074, T075

落地位置：core/memory / storage/memory

实现：candidate→validated→stale/revoked；scope 与 expires，验证来源强制。

验收：未经确认经验不能直接作为验收标准。

P5-10 · 知识/记忆管理页面

模块 M15；依赖 P5-09；对应测试 T071, T072, T073, T074, T075

落地位置：web/knowledge / web/memory

实现：导入、检索预览、查看来源、确认/撤销、清缓存和影响说明。

验收：删除原文同步索引与缓存；既有 Run 显示来源撤销。

P5-11 · 流程与检索集成测试

模块 M24；依赖 P5-10；对应测试 T116, T117, T118, T119, T120

落地位置：tests/p5

实现：同任务切工作流/agent，带知识运行，冲突/无答案/引用失效场景。

验收：所有配置能解释实际运行来源。

P5-12 · P5 文档与迁移

模块 M18；依赖 P5-11；对应测试 T086, T087, T088, T089, T090

落地位置：docs / migrations

实现：更新 Schema/OpenAPI/用户说明，迁移已存在 P3/P4 数据库并保留历史。

验收：升级后旧任务可读，DSL 版本不兼容时有诊断。

P6 · 跨端 Desktop v1.0 产品化

以完整可用而非功能演示为目标，交付两个平台安装包。

P6-01 · 全页面视觉一致性

模块 M22；依赖 P5-12；对应测试 T106, T107, T108, T109, T110

落地位置：apps/web / packages/ui

实现：对照原型完成所有 P6 页面，亮暗主题、空/忙/失败/无权限状态。

验收：关键布局/配色/层级与设计 Token 一致，无占位按钮。

P6-02 · 键盘、可访问性与 DPI

模块 M22；依赖 P6-01；对应测试 T106, T107, T108, T109, T110

落地位置：ui/a11y / tests/ui

实现：Ctrl/Cmd 快捷键、焦点陷阱、屏幕阅读标签、减少动画、中文排版。

验收：1280/1600 与 100/125/150%DPI 验收。

P6-03 · 应用预览与代码浏览

模块 M17；依赖 P6-02；对应测试 T081, T082, T083, T084, T085

落地位置：desktop/preview / web/artifacts

实现：预览独立 webContents 且无 preload；允许 origin 白名单；diff 只读。

验收：被测网页无法访问 Host API。

P6-04 · 诊断、隐私与清理

模块 M23；依赖 P6-03；对应测试 T111, T112, T113, T114, T115

落地位置：web/settings / host/diagnostics

实现：敏感字段脱敏、artifact 保留期、手动导出/清理、usage 透明。

验收：导出包不含凭据，清理不删除用户主仓库。

P6-05 · 应用退出与托盘生命周期

模块 M01；依赖 P6-04；对应测试 T001, T002, T003, T004, T005

落地位置：desktop/lifecycle

实现：关闭窗口继续后台的显式选项、彻底退出安全取消、睡眠提示。

验收：用户知道任务是否仍运行，重开不重复 Host。

P6-06 · Mac 签名/公证包

模块 M23；依赖 P6-05；对应测试 T111, T112, T113, T114, T115

落地位置：build/macos / CI

实现：arm64/x64 平台测试、代码签名、公证；无凭据只产标注内部包。

验收：全新 Mac 用户目录可安装，升级后凭据仍可用。

P6-07 · Windows 安装与签名

模块 M23；依赖 P6-06；对应测试 T111, T112, T113, T114, T115

落地位置：build/windows / CI

实现：x64 签名安装、权限/UAC、中文路径、卸载保留数据策略。

验收：Windows 实机完整跑一任务，不能只测网页。

P6-08 · 安全更新与数据迁移

模块 M18；依赖 P6-07；对应测试 T086, T087, T088, T089, T090

落地位置：host/updater / storage

实现：更新任务 drain、完整性检查、迁移备份、失败恢复、降级检测。

验收：旧 schema 不被新版本半迁移；中断可恢复。

P6-09 · 完整功能/Agent 对照验收

模块 M24；依赖 P6-08；对应测试 T116, T117, T118, T119, T120

落地位置：tests/release / evals

实现：执行 T001-T095 及 T106-T120 适用项；真实任务重复测并记录人工介入。

验收：失败项无假通过；高危/数据损坏 0 遗留。

P6-10 · v1.0 用户指南与发布说明

模块 M23；依赖 P6-09；对应测试 T111, T112, T113, T114, T115

落地位置：docs/user-guide / release

实现：安装、配置、第一任务、权限、恢复、限制、已测支持矩阵。

验收：另一台电脑按指南可完成需求到交付。

P7 · 远程宿主与安全网关

保持核心不变，给在线 Windows/Mac 主机增加受控远程入口。

P7-01 · Host 常驻模式

模块 M20；依赖 P6-10；对应测试 T096, T097, T098, T099, T100

落地位置：host/lifecycle / desktop/settings

实现：允许无窗口托盘运行；明确用户会话/睡眠限制；退出关闭服务。

验收：远端 UI 离线不影响已在 Host 确认的 Run。

P7-02 · HTTPS 入口和网关配置

模块 M20；依赖 P7-01；对应测试 T096, T097, T098, T099, T100

落地位置：host/gateway / docs/remote

实现：本地 loopback 端口+显式私网 HTTPS 部署说明，同源静态 PWA 和 API。

验收：默认远程关闭，裸公网端口不存在。

P7-03 · 设备配对生命周期

模块 M20；依赖 P7-02；对应测试 T096, T097, T098, T099, T100

落地位置：core/devices / web/devices

实现：nonce≥128 位/10min/hash、local confirm、单次消费与设备项目 scope。

验收：重放/过期/暴力请求被拒绝。

P7-04 · 会话与 CSRF

模块 M17；依赖 P7-03；对应测试 T081, T082, T083, T084, T085

落地位置：gateway/auth

实现：HttpOnly Secure cookie、会话 rotate、Origin 验证、CSRF token、revoke。

验收：跨站请求及已撤销 session 无权限。

P7-05 · Command HTTP 适配

模块 M19；依赖 P7-04；对应测试 T091, T092, T093, T094, T095

落地位置：gateway/commands

实现：公开白名单业务命令映射同 CommandBus；忽略客户端 actor 与 scopes。

验收：远端无法 executeShell/installPlugin/writeCredential。

P7-06 · SSE 增量订阅

模块 M19；依赖 P7-05；对应测试 T091, T092, T093, T094, T095

落地位置：gateway/events

实现：cookie 认证、心跳、项目过滤、cursor 恢复、backpressure、revocation。

验收：重连重复事件不会重复状态/动作。

P7-07 · 远端权限与审批 freshness

模块 M20；依赖 P7-06；对应测试 T096, T097, T098, T099, T100

落地位置：policy/remote / core/approvals

实现：每次批准重新读取 revision/hash，手机允许范围收窄。

验收：旧批准 409，敏感默认只允许本地主机。

P7-08 · 远程连接管理页面

模块 M20；依赖 P7-07；对应测试 T096, T097, T098, T099, T100

落地位置：web/devices / desktop/remote

实现：Host 地址/状态/证书入口说明/设备撤销/只读模式/审计。

验收：不能把在线网关显示为执行器一定在线。

P7-09 · 弱网与 Host 崩溃测试

模块 M24；依赖 P7-08；对应测试 T116, T117, T118, T119, T120

落地位置：tests/remote

实现：断流、sleep、token 过期、两设备抢审批、进程崩溃与 revocation。

验收：无离线审批补发，恢复状态一致。

P7-10 · 远程试用指南与安全闸门

模块 M20；依赖 P7-09；对应测试 T096, T097, T098, T099, T100

落地位置：docs/remote-runbook

实现：示例网络只是参考；检查私网访问、TLS、权限与撤销后开放 P8。

验收：手机在真实另一网络经私网连接通过，不伪称公网通用。

P8 · 手机 PWA Companion

在小屏完成查看、澄清、审批、开始/暂停和取消，执行仍在 Host。

P8-01 · 移动 App 布局与路由

模块 M21；依赖 P7-10；对应测试 T101, T102, T103, T104, T105

落地位置：apps/web/mobile

实现：≤767 切移动导航；Inbox 优先，任务详情为整页，不缩小 Desktop 三栏。

验收：390×844 与横屏页面清晰、44px 点击区。

P8-02 · 设备连接与配对 UI

模块 M21；依赖 P8-01；对应测试 T101, T102, T103, T104, T105

落地位置：mobile/connect

实现：扫码/输入、等待主机确认、错误/过期/撤销状态。

验收：配对成功不暴露长期 token，退出清 session。

P8-03 · 待处理与任务列表

模块 M21；依赖 P8-02；对应测试 T101, T102, T103, T104, T105

落地位置：mobile/inbox / mobile/tasks

实现：优先展示待我批准/阻塞，筛选项目/Host，cursor 分页。

验收：离线标时间和只读，不能显示假实时。

P8-04 · 移动任务详情与 Diff 摘要

模块 M21；依赖 P8-03；对应测试 T101, T102, T103, T104, T105

落地位置：mobile/task-detail

实现：目标、AC、活动、折叠 diff/证据，支持纯文本与跳转文件。

验收：敏感/无权限产物不返回，超大 diff 按页加载。

P8-05 · 移动审批与危险确认

模块 M21；依赖 P8-04；对应测试 T101, T102, T103, T104, T105

落地位置：mobile/approval

实现：先刷新 scopeHash，展示权限/快照变化，再确认；重复点击幂等。

验收：过期与版本变化拒绝，用户必须重新审阅。

P8-06 · 移动聊天与修订草稿

模块 M03；依赖 P8-05；对应测试 T011, T012, T013, T014, T015

落地位置：mobile/chat

实现：自然语言建草稿、补充信息、修订；离线仅存消息草稿。

验收：不会通过 service worker 重放审批/开始命令。

P8-07 · PWA 安装与缓存策略

模块 M21；依赖 P8-06；对应测试 T101, T102, T103, T104, T105

落地位置：web/sw / manifest

实现：缓存静态壳与允许只读摘要；/api 写入/证据敏感数据不缓存。

验收：清缓存不丢 Host 数据，设备撤销后本机缓存可清。

P8-08 · 断线重连与通知入口

模块 M21；依赖 P8-07；对应测试 T101, T102, T103, T104, T105

落地位置：client/remote-transport

实现：重连 snapshot+cursor；通知初版为站内列表，不承诺后台推送。

验收：手机关页后 Host 继续；重开显示最新权威状态。

P8-09 · iOS/Android 浏览器实测

模块 M24；依赖 P8-08；对应测试 T116, T117, T118, T119, T120

落地位置：tests/mobile

实现：Safari 与 Chromium、不同网络、输入法、横竖屏、登录过期。

验收：每端真实批准一次当前任务并拒绝旧审批。

P8-10 · v1.1 发布与 Capacitor 预留

模块 M23；依赖 P8-09；对应测试 T111, T112, T113, T114, T115

落地位置：docs/mobile / platform-bridge

实现：交付 PWA 用户指南；定义 push/secureStore/scanner 接口，原生实现后续。

验收：不将 PWA 包装成已经上架原生 App。

P9 · 可选增强与持续扩展

只在 Desktop 和远程稳定后做，不阻塞 v1.0/v1.1。

P9-01 · 只读并行 Review

模块 M06；依赖 P8-10；对应测试 T026, T027, T028, T029, T030

落地位置：core/parallel

实现：fork 仅固定 snapshot 只读节点；join 收齐/超时后按明确规则汇总。

验收：两个 Reviewer 不共同写源代码，失败不以多数票隐藏。

P9-02 · 独立写分支与集成节点

模块 M10；依赖 P9-01；对应测试 T046, T047, T048, T049, T050

落地位置：workspace/integration

实现：每写 Agent 独立树，显式合并节点产生新 snapshot 并重验。

验收：冲突需人工/明确修复，不复用分支通过结论。

P9-03 · 外部插件包与签名审核

模块 M08；依赖 P9-02；对应测试 T036, T037, T038, T039, T040

落地位置：plugin-host/external

实现：公开 SDK、RPC、包完整性、授权/卸载/迁移；单独威胁评审。

验收：未知来源不自动执行，权限可审计撤回。

P9-04 · 更多执行器与协议

模块 M09；依赖 P9-03；对应测试 T041, T042, T043, T044, T045

落地位置：plugins/executor-*

实现：基于公开协议/SDK，生成独立兼容记录和同一合约测试。

验收：不因 CLI 有终端就伪造结构化/暂停/模型兼容。

P9-05 · 混合检索与经验策略

模块 M14；依赖 P9-04；对应测试 T066, T067, T068, T069, T070

落地位置：context/hybrid / memory/experience

实现：FTS+向量+RRF 对照评测，脱敏经验与项目 facts 分离。

验收：检索收益有数据，来源权限先过滤。

P9-06 · 受控策略改进

模块 M24；依赖 P9-05；对应测试 T116, T117, T118, T119, T120

落地位置：evals/evolution

实现：candidate patch→holdout eval→人审→小范围新 Run→回滚。

验收：不能修改隐藏答案、权限或验收标准。

P9-07 · Capacitor 原生手机壳

模块 M21；依赖 P9-06；对应测试 T101, T102, T103, T104, T105

落地位置：apps/mobile

实现：复用 Vue 与 remote client，分别实现安全存储/推送/扫码及商店打包。

验收：手机仍不执行 CLI，iOS/Android 真机验证。

P9-08 · Linux 无头 Host 与公网方案评估

模块 M20；依赖 P9-07；对应测试 T096, T097, T098, T099, T100

落地位置：apps/host / docs/adr

实现：先证明 Node 独立运行和 secret backend，再设计服务安装/身份/Relay 威胁模型。

验收：未完成安全审核不宣称 NAS/公网 Relay 生产可用。

21 · 完整功能验收用例

以下 120 条是待实施的产品验收规格，不是已执行报告。每条都应实现真实自动化或明确的人工验收步骤；状态保留 specified_not_executed，直到实际应用完成测试。

T001-T120 覆盖所有 24 模块。测试不仅验证正常路径，也验证重复、越权、版本过期、取消、崩溃和离线；模型演示通过不能替代这些确定性测试。

QAM01 · 验收 · 桌面壳与跨端客户端

用例	前置	操作	预期
T001 未经授权 IPC	普通 renderer 或被嵌网页	调用未公开通道/伪造 sender	拒绝并审计，核心数据未改变
T002 第二实例	Host 已有运行任务	再次启动应用	聚焦已有窗口，不启动第二写 Host
T003 Renderer 重载	任务运行中	强制 renderer 崩溃并重载	重读权威状态，不重复启动 Run
T004 跨平台快捷键	Mac/Windows 正式包	执行新任务/命令面板/关闭窗口快捷键	分别使用 Cmd/Ctrl，操作和焦点符合设计
T005 布局缩放	1280 和 1600 窗口	切 100/125/150%DPI	主要操作可见，看板横滚而非文字截断

QAM02 · 验收 · 项目、环境与初始化检查

用例	前置	操作	预期
T006 非法项目目录	项目向导	输入空/不存在/无读取权限路径	字段错误不写 Project
T007 非 Git 目录	存在普通目录	连接并拒绝初始化 Git	不自动 git init 或安装依赖
T008 脏主工作区	仓库有未提交文件	连接与启动隔离任务	原文件 hash 保持不变
T009 符号链接越界	repo 下链接指向私有目录	尝试读取/写入该链接	按 policy 拒绝，未泄漏目标内容
T010 Windows 中文路径	含中文/空格/括号的目录	建立 worktree 并执行 argv 命令	无拼接注入，结果路径正确

QAM03 · 验收 · 左侧自然语言入口与任务整理

用例	前置	操作	预期
T011 模糊需求	用户说登录页好看一点	生成任务草稿	提出可选澄清，未把未确认审美写成已批准事实

用例	前置	操作	预期
T012 结构化输出损坏	模型输出非法 JSON	执行修复两次仍失败	显示可编辑草稿和错误，不执行代码
T013 重复消息提交	相同 idempotencyKey	双击发送	仅一条消息/一个草稿请求
T014 聊天提示越权	用户/文档含伪授权语句	请求跳过审核合并	仅生成受控提议或拒绝，Approval 不可伪造
T015 无模型手工模式	模型未配置或网络失败	手工创建标准任务	可保存草稿/批准，不伪称模型生成

QAM04 · 验收 · Task Contract、版本与人类审批

用例	前置	操作	预期
T016 未批准任务开工	Task 为 draft	调用 StartTask	FORBIDDEN 或状态冲突，无 workspace 写入
T017 并发批准	同 revision 两客户端	同时 Approve	仅一次事件，另一请求幂等返回或冲突
T018 任务修订使审批失效	已有 pending approval	更新 goal 或 AC 后批准旧 hash	STALE_APPROVAL，重新审阅
T019 拒绝与过期	pending 已过期或被拒绝	再次批准/使用授权	拒绝，任务不自动开工
T020 验收来源追溯	含来源消息与用户决定	打开每条 AC 来源	定位正确或明确来源已撤回

QAM05 · 验收 · 看板、任务详情与自然语言控制

用例	前置	操作	预期
T021 跨列越过门禁	尚未 Review 任务	拖拽到 Done	原状态不变，展示缺少 Review/Verify/人审
T022 筛选与数量	多状态任务 fixture	按 Agent/优先级/状态筛选	数量一致，隐藏卡片不改变任务状态
T023 重复事件投影	已有 seq 事件	重新投递相同 eventId	不重复卡片/活动/计数
T024 空和无权限状态	无任务或只读 scope	打开看板	空状态有正确行动，无权限操作禁用
T025 键盘任务移动	焦点在卡片	使用菜单/快捷键移动	等同语义命令，焦点可追踪且门禁有效

QAM06 · 验收 · workflow模板、编辑器与编译器

用例	前置	操作	预期
T026 workflow主路 径环	含 A→B→A	发布流程	编译拒绝，标出环，草稿可保留
T027 不可达和缺 插件	有孤立节点/缺绑定	发布或启动	静态错误，未部分启动执行器
T028 能力不兼容	Reviewer 要求 enforced readOnly	选择不支持执行器	无法启动，明确原因
T029 旧 Run 配置 冻结	Run 用 workflow@1	发布 workflow@2	旧 Run 仍引用@1，UI 可查看差异
T030 条件和返工 边界	DSL 含非法字段或超限返 工	执行编译/路由	非法条件拒绝；达到全局上限升级人 类

QAM07 · 验收 · 调度、Run、返工与恢复

用例	前置	操作	预期
T031 重复执行结 果	Attempt 已经 terminal	重放 result	不重复推进节点或创建产物
T032 过期 epoch 写入	旧进程晚回包	提交新 Run 不匹配 epoch	STALE_RESULT 仅审计，新状态不 变
T033 429 有限重 试	上游明确未执行动作	连续返回 429	有限退避，预算耗尽后 blocked，无 无限重试
T034 崩溃副作用 未知	命令已可能执行但结果未记	杀 Host 后重启	reconcile 或要求人工，不直接重跑 合并
T035 取消进程树	执行器有子进程	取消并等待 grace	确认全退出才释放；否则 quarantined

QAM08 · 验收 · 插件注册、依赖与生命周期

用例	前置	操作	预期
T036 注销资源	插件注册服务和监听器	activate/dispose 反复 10 次	监听器/进程/服务回到基线
T037 部分激活失 败	第二项注册抛错	加载插件	逆序清理第一项，宿主仍可用
T038 活跃插件升 级	Run 绑定 0.1.0	尝试卸载/更新	draining 或拒绝，不替换运行版本

用例	前置	操作	预期
T039 Manifest 非法	重复 id/平台错误/未知权限	发现清单	entry 未执行，具体错误可见
T040 插件崩溃	插件进程或激活异常	崩溃注入	对应任务异常，界面和其他只读数据可访问

QAM09 · 验收 · 执行器、模型与 Agent 配置

用例	前置	操作	预期
T041 真实双适配器	合法账号与测试 repo	用两个执行器跑同合同	结果可归一，支持组合记录真实日志
T042 不支持模型	能力列表不含 modelId	保存 Profile 并启动	拒绝，不回落到其他模型而不告知
T043 取消与恢复声明	probe 各布尔能力	测试取消/原生 resume	声明与实测一致，不支持显示不可用
T044 伪成功输出	stdout 说完成但无 schema 结果	结束执行器	inconclusive 或 failed，不推 Done
T045 认证失效	key 过期或未登录	启动/运行途中失效	暂停并提示配置，不泄漏凭据不换账户

QAM10 · 验收 · Git 工作区、快照与交接

用例	前置	操作	预期
T046 并发写租约	同 workspace 已有有效 lease	再启动写 Attempt	拒绝/排队，始终单 writer
T047 新增文件快照	Agent 创建未跟踪文件	冻结 snapshot	允许文件纳入，hash 可重建
T048 Git 命令注入	恶意分支/路径参数	通过 API 提交	参数校验+argv 拒绝，未运行额外命令
T049 链接/路径逃逸	artifact 路径含../或链接	冻结/读取文件	只允许根目录规范路径
T050 主分支前移	验收后目标分支更新	请求合并旧 base	冲突/重验，不能沿用旧验证直接合并

QAM11 · 验收 · Review 与问题返工

用例	前置	操作	预期
T051 Review 空泛阻塞	报告无位置/依据	提交 blocking issue	按 Schema/语义校验拒绝或标待确认，不伪造证据
T052 Review 旧快照	开发已产生新 snapshot	接收旧 Review approved	标 stale，不满足当前门禁
T053 Reviewer 越权写入	read-only Profile	调用写入/修改产品代码	被实际限制或在不支持时拒绝启动；不静默成功
T054 问题去重与历史	同一问题多轮出现	提交新 Review	关联原 issue 与新 attempt，保留演变
T055 人工风险接受	有非安全阻塞建议	Owner 选择接受风险	记录理由/actor/version，显示 waived 非 pass

QAM12 · 验收 · 验证、人工验收与交付

用例	前置	操作	预期
T056 未配置测试	项目无 test 命令	运行验证	not_configured+人工验收待办，不自动绿灯
T057 伪造报告路径	外部结果指向任意文件	导入证据	artifact 服务限制根路径和 MIME，拒绝
T058 退出码权威	日志 PASS 但 exitCode=1	处理验证结果	failed 且原始证据可见
T059 验收快照漂移	人正查看 snapshot A	开发更新 B 后点击通过	409 要求查看新版本
T060 合并幂等	同 merge operation key	重复提交/Host 重启再查	只发生一次预期合并，结果 reconcile

QAM13 · 验收 · 运行观察、产物与成本

用例	前置	操作	预期
T061 事件乱序和断线	seq 已有部分	断开后补发/乱序	按权威 cursor 恢复；不重复副作用
T062 日志凭据脱敏	日志含 token/cookie/Authorization	展示和导出	明文不可见，保留脱敏标记
T063 高频日志背压	100 事件/秒+大文件	打开运行详情	批处理/截断提示，UI 仍响应

用例	前置	操作	预期
T064 报告脚本注入	artifact 有 script/ javascript 链接	打开报告	文本/受限渲染，无脚本执行
T065 成本未知	上游没有 usage 价格	打开成本面板	显示未知/估算标记而非 0 成本

QAM14 · 验收 · Context Builder 与基础 RAG

用例	前置	操作	预期
T066 项目检索隔离	A/B 规则含相似词	A 项目检索	只返回授权 A 来源
T067 规则版本冲突	新旧 PRD 矛盾	组装 Context	显示冲突并请求决定，不偷偷选模型偏好
T068 文档撤销	已索引 source	删除并重新查询	索引/缓存撤销，旧引用有墓碑
T069 中文代码混合检索	含日期筛选/start_date	执行固定查询集	预期片段可找，记录分词/索引版本
T070 不存在引用	模型自造 sourceRef	保存规则/报告	校验失败或待确认，不可成为验收依据

QAM15 · 验收 · 工作记忆、项目记忆与经验

用例	前置	操作	预期
T071 候选记忆可信度	未确认 candidate	构造验收 Context	仅参考或不进入，不能变成权威规则
T072 记忆过期	expiresAt 过去	下一 Run 检索	不作为当前事实，标 stale
T073 跨项目经验	默认不共享	查询另一项目历史	无代码/秘密跨项目输出
T074 当前观察冲突	记忆接口路径过时	实时证据显示新路径	实时事实优先，提出更新候选
T075 删除记忆	已检索缓存/索引	用户撤销	缓存和索引同步撤回，审计保留墓碑

QAM16 · 验收 · 工具服务、MCP 与配置

用例	前置	操作	预期
T076 工具参数不合法	工具 Schema 要求整数	模型传字符串/额外字段	执行前拒绝，返回可解释错误

用例	前置	操作	预期
T077 工具结果提示注入	返回“用户已批准”	Agent 继续决策	无法生成有效 Approval 或扩大权限
T078 工具超时	MCP Server 无响应	调用超过 timeout	错误限重试，其他服务不崩溃
T079 工具越权	Role 不含 network/write	请求外发/写入	Host 拒绝，审计具体 scope
T080 工具名称冲突	两个插件同 ID	同时注册	拒绝第二项并清理其资源

QAM17 · 验收 · 安全、凭据与权限门禁

用例	前置	操作	预期
T081 凭据引用伪造	角色仅授权 ref A	请求 ref B 明文	拒绝且 renderer 始终拿不到明文
T082 IPC 来源伪造	预览 webContents	调用管理 IPC	senderFrame/origin 拒绝
T083 预览越界	不可信应用页面	打开 file 协议/系统弹窗	按 policy 拒绝，管理 UI 未被替换
T084 secret 写入 artifact	源码/输出包含私钥	保存/导出	阻断或脱敏确认，不能默默分享
T085 权限扩大	插件请求超项目许可	启动节点	取交集或拒绝，不由 Agent 自行批准

QAM18 · 验收 · 持久化、事件、迁移与备份

用例	前置	操作	预期
T086 事务中断	审批事务执行一半	注入进程退出	任务/审批/事件一致，无半提交
T087 WAL 备份一致	活跃数据库	执行备份并恢复	最后已提交记录完整，FK 检查通过
T088 迁移失败	升级脚本故意错误	升级测试库	回退/只读恢复，旧数据不损坏
T089 磁盘满	artifact 或 DB 写失败	执行写操作	不标任务成功，错误可诊断
T090 插件 namespace	插件尝试查询 core 表	调用 storage 接口	接口无此权限，不泄漏 SQL 连接

QAM19 · 验收 · 命令、查询、事件与并发控制

用例	前置	操作	预期
T091 客户端 actor 伪造	远端 payload 声称 Owner	调用敏感写	使用 session 真实 actor，伪字段拒绝
T092 幂等 key 内容冲突	已使用 key K	新 payload 复用 K	409 且原操作保持
T093 CAS 并发修改	两个相同 revision 请求	同时更新任务	一成功一冲突，无静默覆盖
T094 事件游标过期	客户端 cursor 落后保留期	重连订阅	resync_required→snapshot，不伪接连续流
T095 未知命令	请求 executeSql/shell.any	调用入口	404/403，不存在通用后门

QAM20 · 验收 · 远程 Host、配对与网关

用例	前置	操作	预期
T096 nonce 重放	已消费配对 nonce	第二设备再消费	拒绝，nonce 只有一次
T097 撤销在线设备	手机有 SSE 与 session	本地撤销后继续写	流关闭且 403；已经提交动作不假撤销
T098 Origin 与 CSRF	已登录手机浏览器	跨站伪造写请求	Origin/CSRF 拒绝
T099 远端权限缩小	设备 scope 被移除	对旧 project 发命令	403，缓存不能授予权限
T100 Host 睡眠/退出	有远端连接	Host 休眠/退出	显示离线/最后更新时间，不自动显示完成

QAM21 · 验收 · 手机 Companion 与断线语义

用例	前置	操作	预期
T101 离线不能审批	已缓存审批页	断网点击批准	仅提示离线，不加入后台重放队列
T102 手机旧版本审批	手机显示 rev1	桌面改成 rev2 后批准	409 强制刷新，用户重新看差异
T103 双设备争抢	两个合法设备同 approval	并发批准/拒绝	一权威决定，另一显示已处理

用例	前置	操作	预期
T104 小屏输入和方向	390×844 与横屏	输入中文长需求并旋转	输入保存，44px 目标和焦点可用
T105 弱网重连	断流/超时/重复返回	重连并发 Start 重试	幂等不重复启动，snapshot 权威

QAM22 · 验收 · 设计系统与无障碍

用例	前置	操作	预期
T106 焦点与键盘	打开 Drawer/Dialog	Tab/ShiftTab/Esc/返回	焦点不掉入底层，退出回触发器
T107 颜色和对比	亮暗主题	检查文本/错误/状态	正文目标 4.5:1，状态含文字非仅颜色
T108 高 DPI 可用	Win150%、MacRetina	比较关键页面	无裁切和模糊可操作文本
T109 长标题与中文	120 字标题/长路径	打开卡片详情和表单	截断有完整访问方式，无按钮挤出
T110 减少动画	系统 reduced-motion	切换运行状态/流程	无强制循环动效，不影响状态理解

QAM23 · 验收 · 设置、发布、更新与诊断

用例	前置	操作	预期
T111 全新安装与卸载	空用户配置	安装/启动/卸载	向导可完成，保留数据政策明确
T112 升级与回滚	旧版本有任务	升级/中断/回滚	迁移一致，旧版 schema 不兼容只读
T113 凭据跨升级	已保存合法 Key	签名一致升级	凭据可用且不暴露；失败有重新授权提示
T114 运行中关闭和退出	active Run	关窗口/真正退出	托盘继续与取消退出行为明确一致
T115 诊断包隐私	有 token 日志与项目路径	导出诊断	用户预览，默认脱敏，不含认证文件

QAM24 · 验收 · Agent 评测与受控改进

用例	前置	操作	预期
T116 公平基线	同任务同预算	比较单 Agent 与流程	预算含全部角色，报告无选择性成功样本

用例	前置	操作	预期
T117 隐藏验收隔离	测试有 holdout 答案	构造 Agent 上下文	隐藏内容不可读取，泄漏检测失败阻发布
T118 坏策略回滚	新 Prompt 增加误报	离线评测/灰度	不推广或回滚到原 hash，不修改旧 Run
T119 成本预算上限	工具循环持续	达到 turn/time/token 预算	升级人类/停止，所有消耗计入
T120 取消不算成功	用户取消或 Host 中断	汇总评测	单列 cancelled/interrupted，不能计 pass

22 · Agent 评测与自进化的完整闭环

先证明单任务交付能可靠推进，再比较多 Agent 是否减少人类介入。基线：同模型/近似预算/同仓库与任务的单执行器；实验：Forge 角色与工作流。每个配置重复多次，保留失败样例，不仅展示最好一次。

指标	定义与防作弊
任务成功率	通过独立验收的任务数/全部尝试任务数；取消、阻塞、未完成单独列出。
错误 Done	标 Done 却违背既定需求或缺证据的次数；属于最高优先级质量问题。
人工介入	澄清、复制反馈、补跑命令、恢复等次数；不要把提示用户大量确认当自动化成功。
返工与成本	总 Attempt、模型 tokens、真实账单或估计标记、墙钟时间；包括 Review 与 Verifier 成本。
检索效果	项目隔离先过安全门；再量化引用准确、召回、无答案处理与任务收益。
安全违规	越权/旧审批成功/秘密泄漏必须为 0；不能用总体通过率抵消。

失败→分类→候选策略 patch→开发集对照→保留集最终验证→人工批准→有限新 Run→监控→回滚。候选绑定旧/new 策略 hash 和适用范围；当前 Run 配置不热更。候选经验未经确认不直接进入高可信上下文。

允许优化：上下文检索/排序、角色提示片段、工具选择启发、有限重试策略。禁止优化：修改安全政策、扩大权限、读取隐藏验收答案、删失败断言、修改已批准 Task Contract、自动安装新插件。

保留集被多次调参后不再视为干净评测，需要重新划分。样本量不足只报告观察，不声称显著提升。所谓自进化是应用策略改进，不等于自动训练底层模型。

23 · 公开命令、持久化与契约索引

统一命令目录包含本地与远端方法。Gateway 只暴露 remoteAllowed=true 的方法；本地专属凭据/插件/配对操作在网关入口拒绝。认证身份由 Host 注入，任何命令都不能凭参数声称自己是 Owner。

方法	职责	远端
projects.create	创建项目	仅本地
projects.archive	归档项目	仅本地
environments.save	保存运行环境	仅本地
conversations.send	发送自然语言消息	受限允许
tasks.createDraft	创建任务草稿	受限允许
tasks.revise	创建任务修订	受限允许
tasks.approve	批准当前任务	受限允许
tasks.reorder	任务同列排序	仅本地
tasks.archive	归档任务	仅本地
runs.start	启动已批准任务	受限允许
runs.pause	请求安全暂停	受限允许
runs.resume	恢复或发起新 Attempt	受限允许
runs.cancel	取消 Run	受限允许
approvals.decide	人类决策审批	仅本地
acceptance.decide	接受当前交付	受限允许
deliveries.merge	显式合并（本地默认）	仅本地
workflows.saveDraft	保存流程草稿	仅本地
workflows.publish	发布流程版本	仅本地
profiles.save	保存角色版本	仅本地
plugins.configure	配置内置插件	仅本地
plugins.disable	安全停用插件	仅本地
knowledge.import	导入已授权文档	仅本地
knowledge.revoke	撤销文档	仅本地
memories.decide	确认/撤销候选记忆	仅本地
devices.revoke	撤销设备（本地）	仅本地

方法	职责	远端
projects.update	更新项目设置	仅本地
environments.probe	检测已批准环境	仅本地
commandPresets.save	创建命令预设草稿	仅本地
commandPresets.approve	授权精确命令配置	仅本地
review.acceptRisk	人类接受具体审查风险	仅本地
verify.run	重跑当前快照验证	仅本地
workflows.validate	校验 workflow 草稿	仅本地
workflows.setDefault	设置项目默认流程	仅本地
executors.probe	探测执行器真实能力	仅本地
plugins.enable	启用内置插件	仅本地
devices.pair.issue	生成配对请求	仅本地
devices.pair.decide	本机决定新设备授权	仅本地
gateway.configure	设置远程网关	仅本地
settings.update	保存应用偏好	仅本地
credentials.set	本地凭据保存或替换	仅本地
credentials.clear	本地凭据撤销	仅本地
diagnostics.prepare	生成待预览的脱敏诊断包	仅本地
updates.check	查询可用签名更新	仅本地
updates.install	安装已验证的更新	仅本地

contracts/openapi.yaml 给出 22 个 HTTP 路径、44 种严格命令 payload 与核心查询结果。命令完成返回 CommandReceipt；202 只代表持久化接收，不代表任务完成。通过 commandId 查询回执，避免弱网重复。输入幂等 key 复用但 payload 不同必须 409。

contracts/schema.sql 含 35 个业务/索引虚拟表（不计 FTS 内部 shadow tables）。数据模型按主文档约束迁移：事件与业务状态同事务、快照关联明确、活跃写租约唯一、pairing/session 只存高熵秘密 hash。SQLite WAL 备份不可只拷主 db 文件，需使用一致性备份机制。[S16]

契约文件	用途
agent-profile.schema.json	角色与执行器绑定
approval-decision.schema.json	人类审批命令结构
approval-request.schema.json	绑定版本的审批请求

契约文件	用途
command-envelope.schema.json	命令外层
config.schema.json	内置执行器配置示例
event-envelope.schema.json	Host 事件外层
executor-capabilities.schema.json	真实能力声明
handoff-bundle.schema.json	跨阶段交接
plan-result.schema.json	计划结构
plugin-manifest.schema.json	插件元数据/权限申请
step-result.schema.json	节点结果/证据
task-contract.schema.json	任务版本/验收
workflow.schema.json	正常 DAG/有界返工

Plugin API 为 TypeScript 接口草案，配套 Schema 负责运行时校验。具体 SDK 方法在适配器内按官方版本实现，不能拿本接口当上游 SDK 调用代码。模板计划和审批输出 Schema 均已提供。

24 · Codex 工作规程与最终交付

先读 AGENTS.md 和 START_HERE.md；选择一个 taskId；检查依赖实际完成状态；读取模块、Schema、页面和 T 用例；实现最小闭环；运行测试并保存证据；报告未验证项；再推进下一任务。不要一次生成全部平台后用假数据填满界面。

本包不是 Forge 成品源码。只执行了规格一致性、SQL 和静态 HTML 原型检查；真实 SDK 能力、Windows/macOS 安装、签名、运行权限与手机远控必须在实施阶段验证。没有账号/平台时标 blocked，不编造通过。

每次提交输出：taskId、变更文件、用户能执行的行为、实际命令与结果、截图/日志、风险与未完成、下一可做任务。不得以 TODO 注释、空函数、硬编码成功或假终端替代实现。

v1.0 最终交付：支持范围内的 Mac 和 Windows 安装包；本地项目接入；自然语言草稿与审批；真实开发/Review/验证/返工；两个执行器互换；可编辑工作流；项目上下文；运行恢复与诊断；签名/更新；文档与完整测试证据。远程与手机另按 P7-P8 验收。

v1.1 交付：在线 Host 的安全 HTTPS 入口、设备配对/撤销、手机 PWA、断线恢复、范围审批；不声称 PC 睡眠仍执行、不让手机拥有任意 Shell、不把两个设备数据库当作同步源。

完整后续扩展清单见 docs/extension-roadmap.md。Linux/NAS Host、Capacitor 原生包、公网 Relay、第三方插件市场、并行写入与高级自进化均独立评估，不能挤进首版导致基本交付迟迟无法运行。

25 · 官方来源与技术核验

核验日期：2026-09-23。以下用于支持技术能力与限制，不代表官方认可 Forge 设计。具体版本可能变化，P0 必须重新确认并锁定兼容矩阵。本文中架构、页面、阶段、工期与指标均为本项目规划，不是外部产品的实际性能结论。

[S01] Electron Process Model

<https://www.electronjs.org/docs/latest/tutorial/process-model>

用途：跨进程架构与 utility process；不将进程隔离等同安全沙箱。

[S02] Electron Security

<https://www.electronjs.org/docs/latest/tutorial/security>

用途：Renderer、IPC、远程内容与导航安全。

[S03] Electron safeStorage

<https://www.electronjs.org/docs/latest/api/safe-storage>

用途：操作系统支持的本地密文保护，非任意同用户进程隔离。

[S04] Tauri 2 Overview

<https://v2.tauri.app/start/>

用途：桌面/移动平台支持与 WebView、Rust 边界，用于选型比较。

[S05] Capacitor Introduction

<https://capacitorjs.com/docs>

用途：后续 iOS/Android Web UI 容器；不在手机运行桌面执行器。

[S06] DeepSeek Harness Architecture

<https://github.com/deepseek-ai/deepseek-harness/blob/master/docs/architecture.md>

用途：服务注册、插件生命周期和能力组合的参考；Forge 不直接依赖其内部实现。

[S07] Codex SDK

<https://developers.openai.com/codex/sdk/>

用途：第一种执行器的官方集成入口，具体接口在 P0 钉住版本后验证。

[S08] Codex App Server

<https://developers.openai.com/codex/app-server/>

用途：备选交互协议，文档对实验性能力有提示；不将其裸露到远端。

[S09] Claude Agent SDK

<https://code.claude.com/docs/en/agent-sdk/overview>

用途：第二执行器与 API Key 认证约束；不能擅自转用 claude.ai 订阅登录。

[S10] pnpm Workspace

<https://pnpm.io/workspaces>

用途：单产品 Monorepo 与 workspace 包依赖。

[S11] Git worktree

<https://git-scm.com/docs/git-worktree>

用途：多工作目录管理；不是安全沙箱。

[S12] Vue Flow

<https://vueflow.dev/>

用途：Vue 节点连线编辑器候选；执行语义由 Forge 定义。

[S13] Reka UI

<https://reka-ui.com/>

用途：无预设视觉的 Vue 可访问性基础组件。

[S14] SQLite WAL

<https://sqlite.org/wal.html>

用途：数据库并发、备份和运行目录限制。

[S15] SQLite FTS5

<https://sqlite.org/fts5.html>

用途：本地关键词检索；中文需显式处理分词策略。

[S16] MCP Architecture

<https://modelcontextprotocol.io/docs/learn/architecture>

用途：工具与资源接入协议，不替代 Forge 插件生命周期。

[S17] OWASP WebSocket Security

https://cheatsheetseries.owasp.org/cheatsheets/WebSocket_Security_Cheat_Sheet.html

用途：实时通信认证、Origin、消息授权与限流；远端初版优先 SSE。

[S18] Tailscale Serve

<https://tailscale.com/docs/features/tailscale-serve>

用途：可选私网 HTTPS 访问方式；不免除应用内认证。

[S19] Electron Code Signing

<https://www.electronjs.org/docs/latest/tutorial/code-signing>

用途：macOS 签名公证、Windows 签名的发布入口；费用与资格另行核实。

[S20] Electron Updates

<https://www.electronjs.org/docs/latest/tutorial/updates>

用途：更新检查与跨平台分发需分别测试。

[S21] Playwright Electron

<https://playwright.dev/docs/api/class-electron>

用途：Electron 自动化支持属于实验性接口；应用业务 E2E 与原生安装测试分离。

[S22] Electron Web Embeds

<https://www.electronjs.org/docs/latest/tutorial/web-embeds>

用途：预览内容与可信管理界面的独立承载。